

Phase 1 Review Packet

Authentication over Better Auth, rate-limited code issuance, a configurable commission engine with frozen fee snapshots, and a ledger proven under concurrent load. This packet separates what was *executed* from what was merely written, and separates what a machine proved from what I proved on my own workstation.

Branch **claude/create-app-repository-1cxsih**

Head **fcb61db**

2 commits

Tests **146 passed • 3 skipped**

GitHub CI **green (run #4)**

Audit **0 advisories**

1

How to read this

Three words are used with fixed meanings throughout, and nowhere else:

WORD	MEANS EXACTLY
TESTED	An automated test or a command was executed and its result observed. The command that produced it is quoted, so you can run it.
NOT TESTED	The code exists and is reviewable, but no test exercises it. Read it, do not trust it.
NOT IMPLEMENTED	It does not exist. There is no stub pretending otherwise.

ON THE WORD "VERIFIED"

It appears in this document only where a test actually ran. Every green mark below carries a provenance column saying *where* it ran — my workstation, GitHub CI, or both. Section 3 exists solely for that distinction, because you asked for it and because the last packet got it wrong.

A note on the numbering

There are now two documents in docs/review/ with "Phase 1" in the title, and that is my fault, not a mistake in your reading. The earlier one — phase-1.html , sent as Afrinext-Phase-1-Review-Packet.pdf — was written when the architecture brief was itself called "Phase 1". The sequence you have since set is **architecture → Phase 0 → Phase 1 (money spine)**. This is the money spine. The earlier file keeps its name and its already-delivered PDF rather than being renamed underneath you; this one is phase-1-money-spine.html .

Where the time is worth spending

Suggested split of a ~2 hour review: ~1h20 code · ~40 min sections 14-16

Sections 14 to 16 are the ones that need a decision from you rather than an opinion. In particular, **section 15 contains a security finding I did not fix**, because fixing it properly is a design change and you told me to stop at decisions that materially affect authentication.

What shipped, and against which decision

Every item below traces to a numbered decision in your review. Nothing was built that you did not ask for.

#	YOUR DECISION	WHAT WAS BUILT	STATUS
1	Adopt Better Auth for authentication, without letting it become authorization	Better Auth 1.7.1 over the <code>pg</code> Pool. Its four tables are declared in our schema and created by our migrations. <code>resolveActor()</code> returns an identity and nothing else; permissions still come only from <code>authorize()</code> .	TESTED
2	Do not blindly replace the users/roles/permissions schema	The Phase 0 schema is intact. <code>users</code> gained one nullable column, <code>auth_user_id</code> . Roles, permissions and scoped assignments are untouched.	TESTED
3	One session store, not two	Our <code>sessions</code> and <code>user_identities</code> tables were dropped in migration 0003. Better Auth's <code>session</code> is the only session store. <code>packages/core/src/auth/session.ts</code> was deleted.	TESTED
4	OTP issuance must never remain unlimited	<code>packages/core/ratelimit</code> : fixed-window counters incremented atomically in PostgreSQL. 5 codes per identifier per hour, 20 per IP per hour, 60 s cooldown, 5 verification attempts. A refusal is a 429 with <code>Retry-After</code> .	TESTED
5	Step-up re-verification before payout-sensitive actions	<code>session.elevatedAt</code> plus <code>markElevated()</code> / <code>requireElevation()</code> , 10-minute window. Step-up issuance is limited harder than sign-in: 3 per hour.	BUILT, NOT WIRED TO A PAYOUT
6	Keep script for now; make a later move to Argon2id possible	Better Auth's hasher is replaced with ours. Parameters stay encoded in the hash, so <code>needsRehash()</code> can drive the migration without invalidating a single stored credential.	TESTED
7	Configurable commissions, resolved by rule, frozen per order	<code>commission_rules</code> + <code>fee_schedules</code> + <code>fee_lines</code> . Rules resolve most-specific-first and deterministically. A schedule is frozen at capture, must total the gross, and is append-only in the database.	TESTED
8	Prove the ledger under concurrency, not by argument	Six concurrent tests. They found a real deadlock — see section 10. That is the single most valuable thing in this phase.	TESTED
9	Audit what matters, never the secret	<code>auth.otp.sent</code> , <code>auth.otp.rate_limited</code> , <code>auth.user.provisioned</code> . The code itself is never audited and never logged.	TESTED
10	Do not fake iPayMoney	Unchanged from Phase 0. The adapter still throws <code>ProviderNotConfiguredError</code> . Three	NOT IMPLEMENTED

#	YOUR DECISION	WHAT WAS BUILT	STATUS
		integration tests remain skipped and are counted as skipped everywhere in this packet.	

THE TWO MID-PHASE DECISIONS YOU APPROVED

Better Auth 1.7.1 requires `drizzle-orm ≥ 0.45.2`, above the 0.38.4 the review had confirmed. I stopped and asked rather than upgrading Drizzle on my own initiative. You chose: (a) keep Better Auth's four tables in *our* migration chain rather than letting its adapter own them, and (b) make its `session` the sole session store. Both are implemented exactly as decided. The Drizzle version moved to 0.45.2 later and for a different reason — a published CVE, section 11 — not to satisfy the adapter, which is still not used.

3

Local verification vs GitHub CI

You asked for these to be distinguished, so they are separated here and never merged anywhere else in this document.

What GitHub CI proved

CI runs on a clean Ubuntu runner against a `postgres:16` service container. It installs from a frozen lockfile, applies the migrations, **then drops the schema and rebuilds it from zero**, then seeds, then runs everything. Nothing on my workstation is involved.

RUN	COMMIT	JOBS	RESULT	FINISHED (UTC)
#4	fcb61db	both	SUCCESS	2026-08-19 18:26
#3	5cbbac5	both	SUCCESS	2026-08-19 18:08
#2	ee04b8f	both	SUCCESS	2026-08-19 10:42
#1	87743b6	both	SUCCESS	2026-08-19 10:35

Run #3, on the main Phase 1 commit, ran these steps and every one of them passed:

JOB	STEPS THAT CONSTITUTE THE PROOF
lint · typecheck · test	create the test database · migrate · rebuild the schema from scratch · seed · <code>pnpm lint</code> · <code>pnpm typecheck</code> · <code>pnpm test</code> · build the web app · ledger concurrency and idempotency under parallel load · assert the ledger reconciles after the suite
dependency scan	<code>pnpm audit --audit-level high</code> (blocks the build) · full advisory report uploaded as a downloadable artifact

What only my workstation proved

These were executed, and their output is quoted in this packet, but they are **not** in CI. Treat them as one person's observation on one machine, reproducible by you with the commands in section 13.

CLAIM	HOW IT WAS PRODUCED	IN CI?
HTTP status codes on the v1 routes (401 / 403 / 200)	<code>curl</code> and a Playwright request context against <code>next start</code>	NO
A signed-in <i>member</i> is refused <code>/api/v1/admin/ledger</code> with 403	Real browser session, then a request on that session	NO
Rate-limit refusal is a live 429 with <code>Retry-After: 6</code>	<code>curl -D-</code> against the running app	STATUS ASSERTED IN A UNIT TEST; THE HTTP ROUND TRIP IS NOT
The sign-in → code → wallet journey renders	Playwright driving the real UI; screenshots in section 12	NO
Locale routing: <code>/fr</code> and <code>/en</code> 200, <code>/xx</code> 404	<code>curl</code>	NO

THE HONEST READING OF THAT TABLE

There is **no browser-level test in CI**. Every HTTP and UI claim in this packet rests on me having run it once, today, on this commit. If a future change breaks the 403 on the admin route, CI will not notice. Making that impossible is a Phase 2 item and is listed in section 16 for your decision, not assumed.

Two commits on `claude/create-app-repository-1cxsih`:

COMMIT	WHAT IT IS	SCALE
5cbbac5	Phase 1: Better Auth, OTP limits, audit, concurrency, commission engine	54 files · +10 993 / -1 078
fc61db	Return 429, not 500, when OTP issuance is refused	2 files · small

`pnpm-lock.yaml` accounts for about 1 755 of those changed lines. The reviewable surface is roughly 2 300 lines of hand-written code and SQL, listed below.

New — read these

FILE	LINES	WHY IT EXISTS
<code>packages/core/src/commissions/index.ts</code>	198	Rule resolution and the frozen fee snapshot. The most consequential new file.
<code>packages/core/src/auth/better-auth.ts</code>	195	The whole Better Auth configuration, in one reviewable place.
<code>packages/core/src/auth/session-bridge.ts</code>	140	Session → identity. Deliberately returns no permissions.
<code>packages/core/src/ratelimit/index.ts</code>	136	Atomic counters and the OTP policy constants.
<code>packages/db/src/schema/commerce.ts</code>	107	Commission rules, fee schedules, fee lines, settlement holds.
<code>packages/db/src/schema/better-auth.ts</code>	90	Better Auth's four tables, declared by us so they are diffed and rebuilt like everything else.
<code>packages/core/src/auth/messaging.ts</code>	74	The SMS/email sender seam. <code>ConsoleSender</code> refuses to run in production without an explicit opt-in.
<code>packages/core/src/auth/errors.ts</code>	23	<code>RateLimitedError</code> , <code>ElevationRequiredError</code> .

Migrations

MIGRATION	LINES	EFFECT
<code>0002_better_auth_tables</code>	83	Creates <code>user</code> , <code>session</code> , <code>account</code> , <code>verification</code> .
<code>0003_retire_superseded_auth_tables</code>	13	Drops our <code>sessions</code> and <code>user_identities</code> . Two sources of truth become one.
<code>0004_commission_and_settlement</code>	66	Commission rules, fee schedules, fee lines, settlement holds.
<code>0005_fee_snapshot_immutable</code>	43	Append-only triggers on the fee tables, and the deferred constraint that fee lines must total the gross.

New in the web app

Route handlers `/api/auth/...all` , `/api/v1/me` , `/api/v1/wallet` , `/api/v1/admin/ledger` ; pages `/[locale]` , `/[locale]/sign-in` , `/[locale]/wallet` ; and `src/lib/{auth,session,api,auth-client}.ts` . All of `apps/web/src` is 2 805 lines including the untouched Phase 0 prototype.

Deleted

`packages/core/src/auth/session.ts` and its tests. Superseded by Better Auth's session; leaving it would have been the second source of truth you rejected.

Current state of the schema, read out of a live PostgreSQL 16 after applying all six migrations:

OBJECT	COUNT	DETAIL
Tables	28	24 ours, 4 Better Auth's — all declared in our schema.
Views	1	<code>ledger_account_balances_derived</code> — the truth the cache is checked against.
Migrations	6	All applied; all replayed from zero in CI.
Triggers enforcing invariants	9	Listed below.
Named check constraints	18	Including <code>otp_purpose_step_up_only</code> , new this phase.

The nine triggers

TRIGGER	ON	WHAT IT MAKES IMPOSSIBLE
<code>ledger_entries_must_balance</code>	<code>ledger_entries</code>	An unbalanced transaction. Deferred, so it fires at commit.
<code>ledger_entries_currency_matches_account</code>	<code>ledger_entries</code>	Posting XOF into an EUR account.
<code>ledger_entries_append_only</code>	<code>ledger_entries</code>	UPDATE or DELETE on a posted entry.
<code>ledger_transactions_append_only</code>	<code>ledger_transactions</code>	Rewriting a transaction header.
<code>fee_lines_must_total_gross</code>	<code>fee_lines</code>	A fee snapshot whose lines do not add up to the gross. New this phase.
<code>fee_lines_append_only</code>	<code>fee_lines</code>	Restating a past order's commission. New this phase.
<code>fee_schedules_append_only</code>	<code>fee_schedules</code>	Editing a frozen schedule. New this phase.
<code>audit_logs_append_only</code>	<code>audit_logs</code>	Erasing your own tracks.
<code>consent_records_append_only</code>	<code>consent_records</code>	Rewriting what someone agreed to.

WHY THE FEE TRIGGERS MATTER MORE THAN THEY LOOK

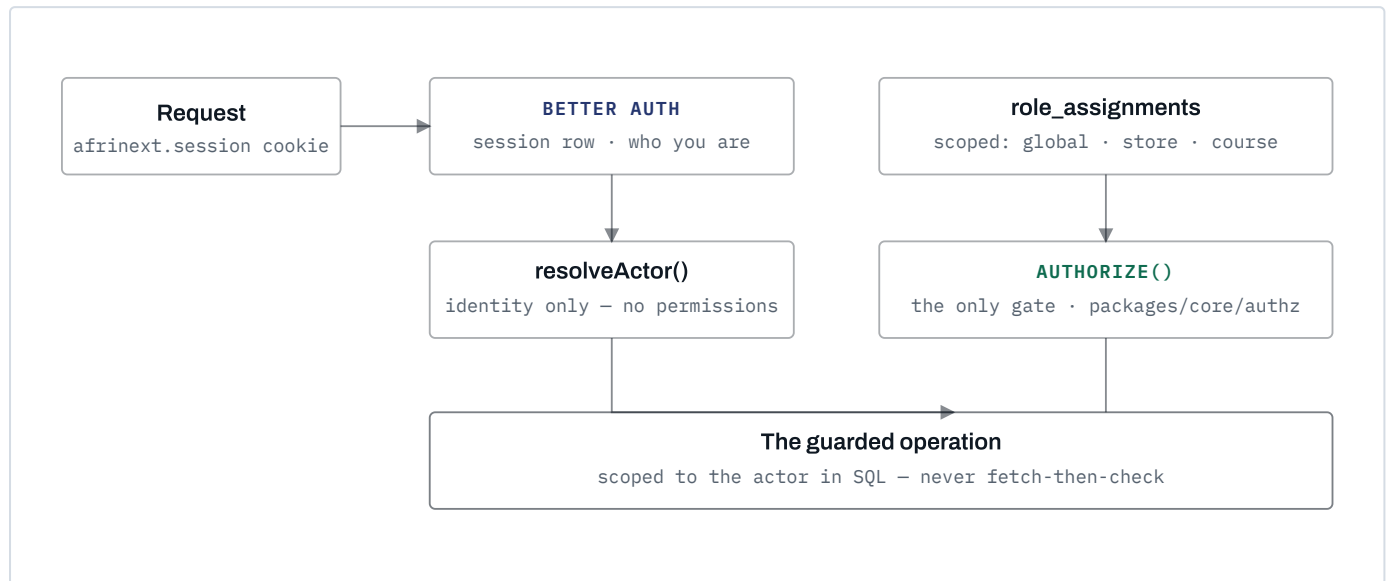
A commission rule is *configuration* — it will change. If a past order's fee lines could be recomputed from the current rule, then changing a rule would silently restate history and the ledger would disagree with the order. Freezing the snapshot in the database, rather than in application code, means a future service written in another language cannot get this wrong either.

Tables dropped

`sessions` and `user_identities`. These were Phase 0 work that your review superseded. They are dropped, not left orphaned — an unused table with credentials in it is a liability, not a spare.

Authentication — and the line it does not cross

Your instruction was that authentication must not become authorization. That is a structural claim, so here is the structure.



Better Auth answers exactly one question: **who is this?** It has no path to the right-hand column. A session that Better Auth considers perfectly valid still yields nothing but a user id, and every capability is a separate lookup against scoped role assignments.

What that buys, concretely

- A suspended user gets **no actor at all**, even holding a valid session cookie — the suspension is checked where identity is resolved, not where each feature remembers to check.
- The signed-in member in section 12 gets 403 `authz.denied` on the admin ledger route. Authentication succeeded completely; it simply grants nothing.
- Replacing Better Auth later touches `better-auth.ts` and `session-bridge.ts`. It does not touch a single permission check.

The four tables, and why we own them

Better Auth ships a Drizzle adapter that would create and own `user`, `session`, `account` and `verification`. We do not use it. The tables are declared in `packages/db/src/schema/better-auth.ts` and created by migration 0002, which means they are reviewed in a pull request, rebuilt from zero in CI, and diffable like everything else.

The risk that creates is drift: a Better Auth upgrade could expect a column we do not have. `auth/schema-drift.test.ts` exists for exactly that — it compares what Better Auth's own migration planner wants against what we declare, and fails the build on a mismatch. **TESTED** — 4 tests.

Sessions are rows, so revocation is one statement

`revokeSession()` and `revokeAllSessionsForUser()` delete rows. There is no token to wait out. Both are tested, including that a revoked session no longer resolves.

OTP issuance is limited, not just OTP attempts

Bounding verification attempts alone protects nothing: someone who can request unlimited fresh codes has unlimited attempts, and in Niger every SMS is a real cost. So issuance is limited too.

RULE	LIMIT	WINDOW	BUCKET
Codes per identifier	5	1 hour	otp:send:id:<phone>
Cooldown between codes	1	60 seconds	otp:cooldown:id:<phone>
Codes per IP	20	1 hour	otp:send:ip:<ip>
Step-up challenges per user	3	1 hour	stepup:send:user:<id>
Verification attempts per code	5	—	enforced by Better Auth

The counter is one atomic statement, so two concurrent requests cannot both read "4 used" and both proceed:

```
insert into rate_limit_counters (bucket, window_start, count)
values ($1, $2, 1)
on conflict (bucket, window_start)
do update set count = rate_limit_counters.count + 1
returning count
```

A request that exceeds the limit is *still counted*. That is deliberate: hammering a blocked bucket must not let it drain early. **TESTED** — 14 tests, including a concurrent one that pins the clock so it cannot race the window boundary.

A refusal is a 429, not a 500 **FIXED IN FCB61DB**

The rate limiter was working from the first commit — issuance was refused, both outcomes audited. But an unrecognised throw out of a Better Auth callback becomes a bare 500 with an empty body, so the caller could not distinguish a refusal from a server fault, and no client could implement a sensible retry. It now leaves the handler as a real 429:

```
$ curl -D- -X POST localhost:3000/api/auth/phone-number/send-otp \
-H 'content-type: application/json' -d '{"phoneNumber":"+22790123456"}'

- first request -
HTTP/1.1 200 OK
{"message":"code sent"}

- immediately again -
HTTP/1.1 429 TOO_MANY_REQUESTS
retry-after: 6
{"code":"ratelimit.exceeded","message":"Too many verification code requests. Try again in 6 second(s"}
```

The test now asserts `statusCode === 429` and the error code, rather than merely that something threw — which is what would have caught it the first time.

The secret is never written down

`auth.otp.sent` records the channel and which sender was used. `auth.otp.rate_limited` records the count and the limit. Neither records the code, and the structured logger redacts by key name recursively, so a code cannot reach a log through a nested object either.

Two guards that refuse to run in production

- `ConsoleSender` prints codes to the console. It **throws on startup** in production unless `ALLOW_CONSOLE_SENDER=yes` is set explicitly — the same pattern as the destructive-reset guard.
- The mock payment provider still refuses to load in production, unchanged from Phase 0.

Passwords

Better Auth's default hasher is replaced with Afrinext's scrypt, per your decision to keep scrypt for now. Parameters remain encoded inside each hash, so a later move to Argon2id can verify old hashes while writing new ones and no stored credential is invalidated.

Commissions are configuration, resolved by rule

No rate is a constant anywhere in the code. A rule may name a country, a category, a store, or none of them, and carries a rate in basis points, a fixed minor-unit amount, or both. Resolution is **most specific first**:

```
order by specificity desc, -- a store rule beats a country rule beats the global default
       priority desc,     -- explicit tie-break you control
       effective_from desc,
       id desc             -- total order: the same inputs always give the same answer
limit 1
```

That last line matters more than it looks. Without a total order, two equally-specific rules would resolve by whatever order the planner felt like, and a settlement could not be re-derived years later. **TESTED** — 13 tests, including specificity precedence, tie-breaking, and time windows.

If no rule is in force, `freezeSchedule` **throws** rather than defaulting to zero or to some hard-coded rate. A sale that cannot say what the platform charged does not settle.

Seeded launch rules, all in basis points of gross, all country-agnostic so Niger is data and not a special case:

TRANSACTION TYPE	RATE	BPS
course	18.00 %	1800
digital	18.00 %	1800
service	15.00 %	1500
physical	12.00 %	1200

Referral comes out of the platform's cut, never off the top

A referral line is declared with `basis: { line: "platform" }` and `deductFrom: "platform"`. The seller's share is therefore untouched by whether a referral existed. This is the rule that is easiest to get quietly wrong and hardest to detect afterwards, so it is expressed in the data structure rather than in arithmetic.

The residual rule

Every non-seller line rounds half-up; the seller receives `gross -  $\Sigma$ (other lines)`. The seller therefore absorbs the rounding remainder and the split always re-sums to the gross exactly. In XOF this is not academic — **XOF has zero decimals**, so the minor unit *is* the franc and a one-unit rounding error is a franc that either exists or does not.

The snapshot is frozen in the database

Once `freezeSchedule` commits, the outcome lives in `fee_lines` and the database refuses to change it. A deferred constraint trigger additionally asserts the lines total the gross, so a split that does not add up cannot be written at all — not by this code, not by a future service, not by someone with `psql`.

The reconciliation gate, run on this commit

A real capture → settlement → payout cycle is posted, then the cached balances are compared against `sum(direction × amount_minor)` derived from the entries:

```
{
  "scenario": { "gross": "10000", "seller": "8200",
               "platform": "1620", "referral": "180" },
  "checkedAccounts": 8,
  "drift": 0,
  "unbalancedTransactions": 0,
  "netByCurrency": { "XOF": "0" }
}
Ledger reconciliation clean over a real capture → settlement → payout cycle.
```

Read the numbers: gross 10 000 XOF at 18 % gives a platform cut of 1 800, of which a 10 % referral takes 180, leaving the platform 1 620 — and the seller 8 200, which is unchanged by the referral existing.

TESTED in CI as the final step of every run, so a change that breaks reconciliation cannot merge quietly.

What is deliberately absent

No screen, field, API response or database column calls a seller balance a deposit or protected funds. `/api/v1/wallet` returns, in the payload itself:

```
"note": "Balances are contractual entitlements against Afrinext, not deposits."
```

The ledger records entitlement, not custody — and per your instruction, company registration does not establish authorization for regulated payment activity. Nothing in this phase claims otherwise.

146 passed, 3 skipped, across 15 files. Executed on this commit, both locally and on GitHub CI. The three skipped are the iPayMoney integration tests and are skipped because there is nothing to integrate against — they are counted as skipped everywhere in this packet and never folded into the passing number.

FILE	TESTS	WHAT IT ACTUALLY PROVES
auth/auth.test.ts	19	Password hashing, rehash detection, OTP challenge lifecycle, attempt bounds.
ratelimit/ratelimit.test.ts	14	Windows, cooldowns, per-IP rules, and that concurrent consumers cannot overshoot a limit.
ledger/ledger.test.ts	14	Double-entry invariants, append-only enforcement, currency matching, idempotency.
commissions/commissions.test.ts	13	Rule specificity, deterministic tie-breaks, time windows, frozen snapshots, refusal when no rule applies.
money/money.test.ts	13	Minor units, zero-decimal currencies, refusal of floats. Property-based.
payments/payments.test.ts	13	The provider abstraction; the mock refusing to load in production.
auth/flow.test.ts	11	Phone sign-in end to end, domain provisioning, revocation, elevation, the 429.
authz/authorize.test.ts	11	Scoped permissions, denial by default, suspended users.
money/allocate.test.ts	9	The residual rule. Property-based: splits always re-sum to the gross.
money/currency.test.ts	7	Exponents read from the table, not assumed to be 2.
ledger/concurrency.test.ts	6	Parallel posting, lost-update resistance, idempotency under races. Found the deadlock.
consent/consent.test.ts	6	Versioned documents, append-only consent records.
observability/logger.test.ts	5	Recursive secret redaction by key name.
auth/schema-drift.test.ts	4	Our declared Better Auth tables still match what Better Auth expects.
payments/ipaymoney.integration.test.ts	4	1 asserts the adapter refuses to pretend. 3 skipped — no provider to test against.

Test code is **2 181 lines** against **4 201 lines** of package source — a ratio of about 0.52, concentrated on money and authorization rather than spread evenly.

THIS IS THE FINDING OF THE PHASE

You required concurrency tests. They immediately found a production deadlock in ledger posting that no amount of reading the code had surfaced — including my own reading of it, twice.

What was wrong

`postTransaction` updated the cached balance rows in whatever order the transaction's entries happened to be written. So a transfer $A \rightarrow B$ locked A then B, while a concurrent transfer $B \rightarrow A$ locked B then A. Each held what the other wanted; PostgreSQL detected the cycle and aborted one with a deadlock error.

Under a real marketplace this is not exotic. Two buyers paying two sellers who also buy from each other is enough. It would have appeared as intermittent, unreproducible payment failures in production.

The fix

```
// Lock the balance rows in a deterministic order.
//
// Without this, a transfer A->B and a concurrent transfer B->A each lock
// their two rows in the order the transfers were written, so one holds A and
// wants B while the other holds B and wants A: PostgreSQL detects the cycle
// and aborts one with a deadlock. Sorting by account id means every
// transaction in the system acquires these locks in the same order, which
// makes such a cycle impossible. Found by the concurrent-posting test, not
// by reasoning.
const orderedDelta = [...delta].sort(([a], [b]) => (a < b ? -1 : a > b ? 1 : 0));

for (const [accountId, amount] of orderedDelta) { /* ... */ }
```

Every transaction in the system now acquires balance locks in the same global order, which makes a cycle impossible rather than merely unlikely.

The measurement

CONCURRENCY SUITE	BEFORE	AFTER
Wall time	23 s	0.8 s
Outcome	deadlock aborts, retries	clean

The 23 seconds were the database detecting cycles and the suite retrying. Speed was the symptom; the deadlock was the disease.

This rule is now written into `AGENTS.md` as non-negotiable: anything that locks more than one row sorts first. **TESTED** — the concurrency suite runs as its own named step in CI, so a regression is attributable rather than buried in a 149-test summary.

Current state, executed on this commit both locally and in CI:

```
$ pnpm audit --audit-level high
No known vulnerabilities found
```

That was not the state when the phase started. The scan found real advisories and they were fixed rather than noted:

PACKAGE	SEVERITY	ISSUE	RESOLUTION
drizzle-orm	HIGH	CVE-2026-39356 — SQL injection through identifiers	Upgraded to 0.45.2. Drizzle stays, per your decision; only the version moved.
vitest	CRITICAL	Advisory in the pinned range	Upgraded to 3.2.7.
vite / esbuild	TRANSITIVE	Pulled in below the patched versions	Pinned by root overrides : vite >=6.4.3 , esbuild >=0.25.0 .

WORTH NAMING PLAINLY

The Drizzle advisory is a SQL-injection class issue in the ORM this project routes *every* financial statement through. It was found by a scan you insisted on, not by review. The dependency-scan job now blocks the build on high and critical, and uploads the full advisory report as a downloadable artifact on every run so a low-severity trend is visible before it becomes a high one.

One piece of dead configuration was also removed this phase: a `peerDependencyRules` override pinning the Drizzle adapter's peer to 0.38.4, which no longer applies now that the adapter is unused and Drizzle is 0.45.2. Leaving it would have masked a future peer mismatch. The lockfile is unchanged by its removal, and `pnpm install --frozen-lockfile` still succeeds.

All of this was produced against a production build (`next build` then `next start`) on this commit. None of it is in CI — see section 3.

HTTP behaviour

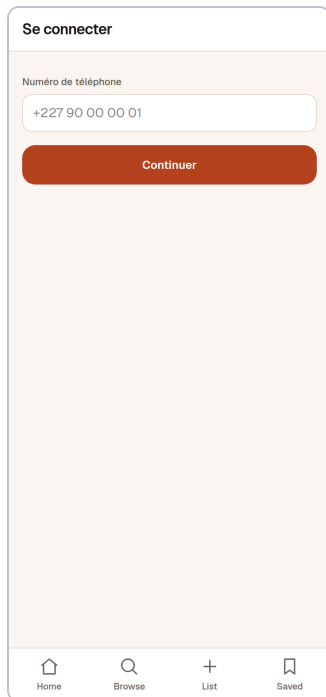
ROUTE	ANONYMOUS	SIGNED-IN MEMBER	READING
/api/v1/me	401	200	Returns the identity and its permission list.
/api/v1/wallet	401	200	Entitlements derived from ledger entries, not from the cache.
/api/v1/admin/ledger	401	403	The one that matters. Authentication fully succeeded; it grants nothing.
/fr/wallet	307	200	Redirects to sign-in when signed out.
/fr/sign-in /en/sign-in	200	200	Both locales route.
/xx/sign-in	404	404	An unknown locale is refused, not silently defaulted.

```
- anonymous -  
{"error":{"code":"auth.required","message":"Authentication required."}}  
  
- signed-in member, admin route -  
{"error":{"code":"authz.denied",  
  "message":"Permission "ledger.read" is not granted on global."}}
```

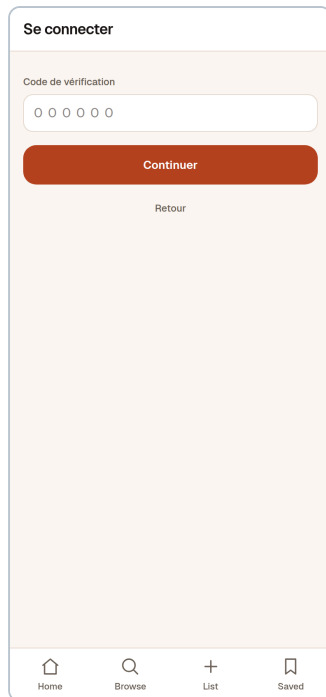
The message names the permission and the scope. That is deliberate: a denial that cannot be diagnosed becomes a denial someone works around.

The journey, end to end

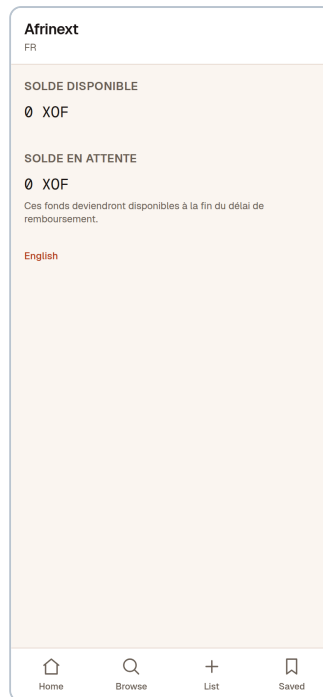
Driven by a real browser at 390×844 — the phone this is built for, not a desktop window narrowed down.



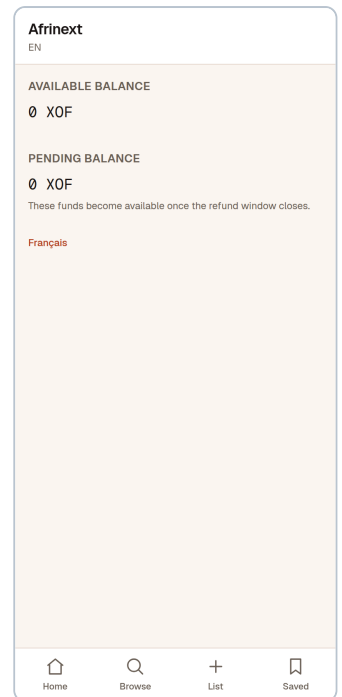
Sign in — The phone step. One field, a tel keyboard, French by default because Niger's default locale is data in the `locales` table, not a constant.



Verification code — The six-digit step. The code was delivered through the sender seam; it is never logged, never audited, and never rendered.



Wallet • FR — 0 XOF, not **0,00 XOF** — the exponent came from the `currencies` table. The pending line reads *funds become available at the end of the refund window*; nothing on this screen calls it a deposit.



Wallet • EN — The same route under `/en`. Locale is a path segment, so both are linkable and an unknown locale 404s rather than silently falling back.

13 Reproduce every claim in this packet

Nothing here needs my machine. Node 22+, pnpm 10+, PostgreSQL 16+.

1 Get the branch and install

```
git clone https://github.com/abdoulasani/Afrinext
cd Afrinext
git checkout claude/create-app-repository-1cxsih
git log --oneline -2          # should show fcb61db, 5cbbac5
pnpm install --frozen-lockfile
```

2 Point it at two databases

```
cp .env.example .env
# set DATABASE_URL and TEST_DATABASE_URL — they must differ.
# The suite truncates every table it touches and refuses to run otherwise;
# that guard fired on me during this phase, working exactly as intended.
```

3 Build the schema and seed it

```
pnpm db:migrate
pnpm --filter @afrinext/core seed
```

4 Run everything

```
pnpm lint          # exits 0
pnpm typecheck     # exits 0
pnpm test          # 146 passed | 3 skipped (149), 15 files
pnpm build         # exits 0
pnpm audit --audit-level high # No known vulnerabilities found
```

5 Prove the ledger separately

```
pnpm --filter @afrinext/core exec vitest run src/ledger/concurrency.test.ts
DATABASE_URL="$TEST_DATABASE_URL" \
  pnpm --filter @afrinext/core exec tsx scripts/reconcile-check.ts
```

The second prints the JSON in section 8. `drift` must be 0 and every currency must net to 0.

6 See the deadlock for yourself

Revert one line — remove the `.sort(...)` in `packages/core/src/ledger/post.ts` — and re-run the concurrency test. It goes

from under a second to roughly twenty-three, with deadlock aborts in the output. Put it back afterwards.

7

Check the HTTP claims

```
ALLOW_CONSOLE_SENDER=yes pnpm start

curl -s -o /dev/null -w '%{http_code}\n' localhost:3000/api/v1/me           # 401
curl -s -o /dev/null -w '%{http_code}\n' localhost:3000/xx/sign-in         # 404

# twice in a row – the second is the rate limiter:
curl -D- -X POST localhost:3000/api/auth/phone-number/send-otp \
  -H 'content-type: application/json' -d '{"phoneNumber":"+22790123456"}'
# 200, then 429 with retry-after
```

For the 403, sign in through the UI at `/fr/sign-in` (the code is printed by `ConsoleSender`), then request `/api/v1/admin/ledger` on that session.

8

Read the CI runs rather than trusting this document

github.com/abdoulasani/Afrinext/actions — runs #1 to #4, all green. Run #4 is this head commit. Every step name is visible; the dependency-scan job attaches its full advisory report as a downloadable artifact.

Read this section as the counterweight to section 9. Everything below is either untested code or absent code, stated plainly.

Built, but not tested

THING	STATUS	WHAT THAT MEANS FOR YOU
Step-up elevation guarding an actual payout	NOT TESTED	The mechanism has tests; nothing yet <i>calls</i> it before moving money, because no payout endpoint exists. The guarantee is unproven in the only context that matters.
Every HTTP route handler	NOT TESTED	No automated test hits a route. The status codes in section 12 came from me running <code>curl</code> once.
Every React component	NOT TESTED	<code>apps/web</code> has no test suite at all. <code>pnpm test</code> in that package prints a placeholder and exits 0.
Email OTP delivery	NOT TESTED	Configured, and phone is the launch path. No email is actually sent by anything.
The consent flow in the UI	NOT TESTED	The tables and core functions are tested. Nothing in the interface presents a document or records agreement yet.
Migration <code>0005</code> has no drizzle-kit snapshot	COSMETIC	It contains only triggers and functions, which drizzle-kit does not model — the same pattern as <code>0001</code> . It applies and replays correctly in CI; it simply will not appear in a generated diff.

Not built

THING	STATUS	NOTE
iPayMoney integration	NOT IMPLEMENTED	The adapter throws <code>ProviderNotConfiguredError</code> . No invented endpoints, no invented auth parameters, no invented webhook payloads, no fabricated success responses. <code>docs/providers/ipaymoney/README.md</code> lists the 13 documentation items needed to build it.
Payouts and withdrawals	NOT IMPLEMENTED	The four-eyes rule — nobody approves their own withdrawal — is designed and has a place in the schema. There is no endpoint to enforce it on yet.
Products, orders, checkout, courses	NOT IMPLEMENTED	Phase 2 and beyond. The commission engine takes a <code>subjectType</code> / <code>subjectId</code> so it is ready for them.
SMS delivery to a real handset	NOT IMPLEMENTED	Only <code>ConsoleSender</code> exists. No SMS provider is chosen, contracted or configured, and none is pretended.
Browser tests in CI	NOT IMPLEMENTED	The gap named in section 3.

RISK 1 – VERIFICATION CODES ARE STORED IN PLAINTEXT

Better Auth writes the OTP into `verification.value` as `<code>:<attempts>`, in the clear. Anyone with read access to that table — a backup, a replica, a leaked dump, a support tool, an SQL-injection foothold — can sign in as any user with a code in flight. Codes live five minutes, which bounds the window but does not close it.

This is **inconsistent with our own standard**: the `otp_challenges` table we wrote in Phase 0 stores `code_hash`, never the code.

I found this while re-verifying the sign-in journey for this packet and **did not fix it**, because the fix is a design change to authentication and you told me to stop at those. What I established:

- Better Auth's `emailOTP` plugin accepts `storeOTP: "hashed"`, defaulting to `"plain"`. One line.
- Its `phoneNumber` plugin — **our launch path** — has no such option. I read the plugin source: it writes `value: `${code}:0`` unconditionally, with no hook to intercept.

So the options are: (a) hash the email path and accept plaintext on the phone path, which is close to cosmetic in a phone-first market; (b) take the phone OTP flow back into our own `otp_challenges` table, which already hashes, and use Better Auth only to mint the session once verification succeeds; (c) accept the risk for launch, documented, with the table's access tightly restricted. **This needs your decision, not mine.**

RISK 2 – NO BROWSER TEST IN CI

The 403 on the admin route is the single most security-relevant behaviour in the running application, and its only proof is that I ran it by hand today. A refactor that broke it would ship green.

RISK 3 – A REFUSED CODE REQUEST STILL WRITES A CODE ROW

Better Auth creates the `verification` row *before* calling our sender, so a rate-limited request has already written a code that will never be delivered. Nothing is sent and no cost is incurred — the limiter does its job — but the row exists and counts toward table growth. Combined with risk 1, an attacker who can read the table does not even need delivery to succeed. Pruning is not implemented.

RISK 4 – THE RATE LIMITER IS PER-INSTANCE-AGNOSTIC BUT NOT PER-INSTANCE-TESTED

Counters live in PostgreSQL and increment atomically, so limits hold across application instances by construction. That property is tested with concurrent callers against one database; it has never run against two application processes, because there has never been more than one.

RISK 5 – REGULATORY POSTURE IS UNCHANGED AND UNRESOLVED

Repeating what the blueprint says, because it does not become less true with more code: NIF and RCCM establish company registration. They do not establish authorization for regulated payment activity, and consent does not substitute for authorization. Nothing in Phase 1 changes this, and no screen implies otherwise. It remains an open item outside engineering's control.

RISK 6 – ONE UN-ADOPTED UPSTREAM DEPENDENCY DECISION

Better Auth is pinned at exactly `1.7.1`, not a range. That is deliberate — an auth library that silently minor-bumps is not something a money system should carry — but it means upgrades are a manual, reviewed act. `schema-drift.test.ts` will fail loudly if an upgrade expects a column we do not declare, which is the point of it.

These are the items that need a yes, a no, or a different instruction. Everything else in this packet is reporting.

#	DECISION	WHAT I RECOMMEND, AND WHY
1	Plaintext OTP storage (risk 1)	Option (b): move phone verification into our own hashed <code>otp_challenges</code> table and let Better Auth mint the session afterwards. It is more work than (a) but it is the only option that makes the launch path match the standard we already set, and it removes a whole class of "a dump of one table is a full account takeover" incident. If you prefer (c) for launch speed, say so and I will document the acceptance rather than quietly carrying it.
2	Browser tests in CI (risk 2)	Add a small Playwright job to CI in Phase 2 covering exactly three things: unauthenticated 401, signed-in member 403 on an admin route, and the sign-in journey completing. Not a broad UI suite — three assertions that would catch an authorization regression.
3	Where step-up elevation is required	The mechanism exists and is unattached. I need the list of actions that must demand it — my assumption is: request a withdrawal, change payout details, change the phone number on an account. Confirm or amend before Phase 2 wires it, because retrofitting it later means auditing every call site.
4	The seeded commission rates	18 % course and digital, 15 % service, 12 % physical, all country-agnostic. These are placeholders I chose to make the engine demonstrable. They are configuration and can change at any time — but they will be in the database from the first real sale onward, so confirm them or replace them now.
5	Referral share	The engine takes a referral rate as basis points <i>of the platform's commission</i> . The reconciliation scenario uses 10 %. No referral rate is seeded and nothing charges one yet. Confirm the model — out of the platform's cut, never off the gross — even if the number comes later.
6	Session lifetime	30 days, refreshed daily, revocable in one statement. That is shorter than typical consumer defaults and longer than a banking default. For a marketplace on shared phones I would keep 30 days but require step-up for anything financial — which is decision 3.
7	OTP policy numbers	5 per phone per hour, 20 per IP per hour, 60 s cooldown, 5 attempts. The per-IP limit is the one I would watch: shared connections and carrier NAT are common, and 20 may be too tight in practice. It is a constant in one file and trivially changed once there is real traffic.
8	SMS provider	Nothing is chosen, so nothing sends. The seam is one interface with two methods. This blocks any real user testing, so it is the practical critical path — more than any code in this phase.
9	Proceed to Phase 2	I am not starting it. Section 18 is a proposal, not a plan in motion.

CORRECTION CARRIED FORWARD FROM THE PHASE 0 PACKET

The first issue of the Phase 0 packet stated that CI had never run. **That was false.** CI had already run and passed twice — runs #1 and #2, on commits `87743b6` and `ee04b8f` — before I wrote the sentence. I did not check, and asserted the pessimistic thing as if it were established.

It was corrected in six places in `docs/review/phase-0.html`, with run links, in commit `ee04b8f`. If you reviewed an earlier copy of that PDF, that is the one claim in it that changed. Section 3 of this packet exists in the shape it does because of that mistake.

Against the exit criterion recorded in the Phase 0 packet

That packet proposed this bar for the next phase: *"a real person registers by phone, accepts the terms, creates a store, publishes a paid digital product, and it appears at a public URL — with every step audited and the ledger untouched because nothing has been bought yet."* Your subsequent brief narrowed the phase to the money spine, so the bar splits:

CLAUSE OF THE CRITERION	STATUS	EVIDENCE OR REASON
A real person registers by phone	MET	Section 12 — journey driven end to end. "Real person" still means a console-printed code: no SMS provider exists.
Every step audited	MET	<code>auth.otp.sent</code> , <code>auth.otp.rate_limited</code> , <code>auth.user.provisioned</code> , on an append-only table.
The ledger untouched because nothing was bought	MET	Wallet reads <code>0 X0F</code> derived from entries; reconciliation nets to zero.
Accepts the terms	NOT MET	Consent tables and core functions are tested. No screen presents a document or records agreement.
Creates a store	NOT MET	Out of scope once the phase became the money spine. Phase 2.
Publishes a paid digital product at a public URL	NOT MET	Same. The commission engine is built to receive it.

Three of six clauses are met. I am not calling that a pass — the phase you actually commissioned was the money spine, and against *that* brief every item in section 2 is delivered. But the older bar should not quietly disappear, so it is scored here.

Standing rules from your briefs

RULE	HELD?	WHERE IT IS ENFORCED RATHER THAN PROMISED
No floating-point arithmetic for money	HELD	<code>bigint</code> minor units plus a currency code; <code>money()</code> rejects a non-integer. Property-tested.
Zero-decimal currencies are not special-cased	HELD	The exponent is read from the <code>currencies</code> table. The wallet renders <code>0 XOF</code> .
The ledger is append-only and double-entry	HELD	Four database triggers. A bypass fails loudly.
Never trust frontend validation for financial or permission-sensitive operations	HELD	Every route resolves the actor server-side and calls <code>authorize()</code> . The 403 in section 12 is issued by the server to a client that asked politely.
Nobody approves their own withdrawal	NOT YET REACHABLE	Designed; no withdrawal endpoint exists to enforce it on.
Seller balances are never called deposits or protected funds	HELD	Stated in the API payload itself; no field or label anywhere says otherwise.
Registration is not authorization for regulated activity	HELD	Nothing in this phase claims it is. Risk 5.
Do not invent iPayMoney endpoints, auth, webhooks or responses	HELD	The adapter throws. Three tests stay skipped rather than passing against a fiction.
Do not claim CI is verified until it has run	HELD	Four runs, listed with commits and timestamps in section 3. The Phase 0 breach of this rule is corrected above.
Never say "verified" unless the test was executed	HELD	Section 1 defines the vocabulary; section 3 says where each proof ran.
Stop and ask on decisions affecting money, security, auth or data integrity	HELD	Stopped once mid-phase on the Drizzle/Better Auth question. Stopping again now on plaintext OTP storage — risk 1, decision 1.
Authentication must not become authorization	HELD	Section 6, with the structure drawn out.
Do not blindly replace the users/roles/permissions schema	HELD	One nullable column added. Nothing replaced.
OTP issuance must never remain unlimited	HELD	Section 7, counted atomically in PostgreSQL.
Do not start Phase 2, rebuild the ledger, recreate the blueprint, or discard Phase 0	HELD	None of the four happened.

A PROPOSAL, NOT A PLAN IN MOTION

No Phase 2 work has started, and none will start without your explicit approval.

The money spine can now price a sale, freeze what was charged, and post it without losing an update. What it cannot do is have a sale to price. Phase 2 is the smallest thing that changes that:

1 Whatever section 16 decides

Decisions 1 and 2 in particular. Plaintext OTP storage should be settled before there are real accounts to take over, and the three-assertion browser job should land before more routes exist to regress.

2 Stores and products

A seller creates a store and publishes a paid digital product at a public URL. This is where the commission engine's `subjectType / subjectId` stops being hypothetical.

3 Consent, presented rather than merely stored

The versioned document machinery exists and is tested. Phase 2 shows a document, records the acceptance against its version, and blocks the actions that require it.

4 Checkout against the mock provider, end to end

Order → capture → `freezeSchedule` → post to the ledger → reconcile. Against the mock, because iPayMoney remains undocumented. This is the first time the whole spine carries a real order.

5 The payout path, with the four-eyes rule enforced

A withdrawal request, an approval by someone else, step-up elevation demanded at the moment of approval. This is where decision 3 has to already be answered.

Proposed exit criterion: a buyer purchases a digital product, the seller's entitlement appears in their wallet with the commission frozen and reconciling to zero drift, a withdrawal is requested, and a second person must approve it — with iPayMoney still absent and still not pretended.

THE THING THAT IS NOT CODE

An SMS provider for Niger. Without one, nobody outside this repository can sign in, and none of the above can be tested by a real user on a real handset. It has been the top non-engineering blocker since the Phase 0 packet and it has not moved.

Phase 1 complete · branch `claude/create-app-repository-1cxsih` · head `fcb61db` · GitHub CI run #4 green · **Phase 2 will not begin without explicit approval.**

Afrinext Technical Blueprint

The architecture for a multi-country African commerce and learning platform built around a double-entry ledger — stack, schema, permission model, money design, security controls and a phased build order.

Rev 2 – Phase 0 authorised

Operator: AFRI NEXT TECHNOLOGIE

Launch: Niger · XOF

iPayMoney: not integrated

CONTENTS

- 00 The read, and one pushback
- 01 Company & regulatory posture
- A Technology stack
- B System architecture
- C Database schema
- D Auth & permissions
- E Financial architecture
- F Marketplace
- G Learning & video
- H Referral network
- I Delivery
- J API architecture
- K Security
- L Project structure
- M Roadmap
- R Risk register
- P What iPay needs
- S Status register
- Q Open decisions

The read, and one pushback

Afrinext is three businesses sharing one identity system. A **marketplace** (physical goods, digital goods, services), a **learning platform** (paid video and documents with entitlement), and a **money system** (wallet, commissions, settlement, payouts). Delivery and the referral network are not separate products — they are two more sources of ledger events.

That framing decides the architecture. The ledger is the spine; everything else is a producer of financial events that the ledger records. A course purchase, a delivered parcel and an ambassador commission are the same shape of thing once they reach the money layer. If that layer is designed last, every module above it grows its own private notion of "balance" and the platform becomes unauditible.

The "one person, one account, many roles" principle is right and it is cheap to honour, provided one rule holds from the first migration: **there is no role column on the user**. Roles are rows, they are scoped to a resource, and they are additive.

The pushback

The module list in the brief is a two-to-three-year product. Built as specified — all modules in parallel — every part arrives shallow, and the hardest, least reversible part (money) gets exercised last, by which point the schema is load-bearing for a dozen features.

Launch one vertical: digital products and courses, one country, one payment rail.

WHY	It exercises identity, roles, stores, catalog, checkout, payments, ledger, commissions, wallet, withdrawals, entitlement and protected video — every hard part except logistics — with no inventory, no couriers, no cash handling and near-instant fulfilment. It is the shortest path to a real settled transaction, which is the only thing that proves the platform works.
INSTEAD OF	Launching the full marketplace, delivery network and creator marketplace together.
TRADE-OFF	Physical goods and delivery slip to a second launch, roughly five weeks of work that starts later rather than never. Ambassadors have a thinner catalog to promote at day one.
REVERSIBLE?	Yes. Nothing in this blueprint's schema or module boundaries assumes the narrow scope — the tables for physical goods and delivery are designed here, just not built first.

Confirmed. The staged scope is now fixed as below. The V2 and V3 architecture stays in this document even though it is not being built yet — removing it would only mean rediscovering it later.

SCOPE		STATUS
V1	Identity, authentication, multiple roles, stores, digital products, PDF/ebooks/guides, courses, learning progress, marketplace, checkout, payment integration, ledger, commission engine, seller financial records, payout architecture, Afrinext Network, admin foundation	BUILDING
V2	Physical products, inventory, delivery partners, delivery state machine, proof of delivery	DESIGNED, NOT BUILT
V3	Creator marketplace, advanced services marketplace, further ecosystem functionality	DESIGNED, NOT BUILT

Launch market is Niger, launch currency XOF. Neither is hard-coded: countries and currencies are rows, and the multi-country design elsewhere in this document is unchanged.

What is in the repository today

The current Afrinext repository holds a mobile-first PWA directory prototype: Next.js 16, Tailwind v4, an in-memory listing store, seed data, and a submission form. It is honest about what it is — there is no database, no authentication, no payments, and no money. In this plan:

ASSET	DISPOSITION
Design tokens, PWA shell, mobile navigation, card and form components	CARRIES FORWARD Becomes the seed of <code>packages/ui</code> .
Next.js 16 + TypeScript + Tailwind v4 setup, lint and build config	CARRIES FORWARD Becomes <code>apps/web</code> inside the monorepo.
<code>src/lib/store.ts</code> , <code>src/lib/seed.ts</code> , the in-memory model	DISCARD Replaced by Postgres and Drizzle.
<code>src/lib/search.ts</code> , <code>validate.ts</code> , the URL-driven filter pattern	REWRITE, KEEP THE SHAPE The pattern is right; the implementation moves to the database and to shared Zod schemas.

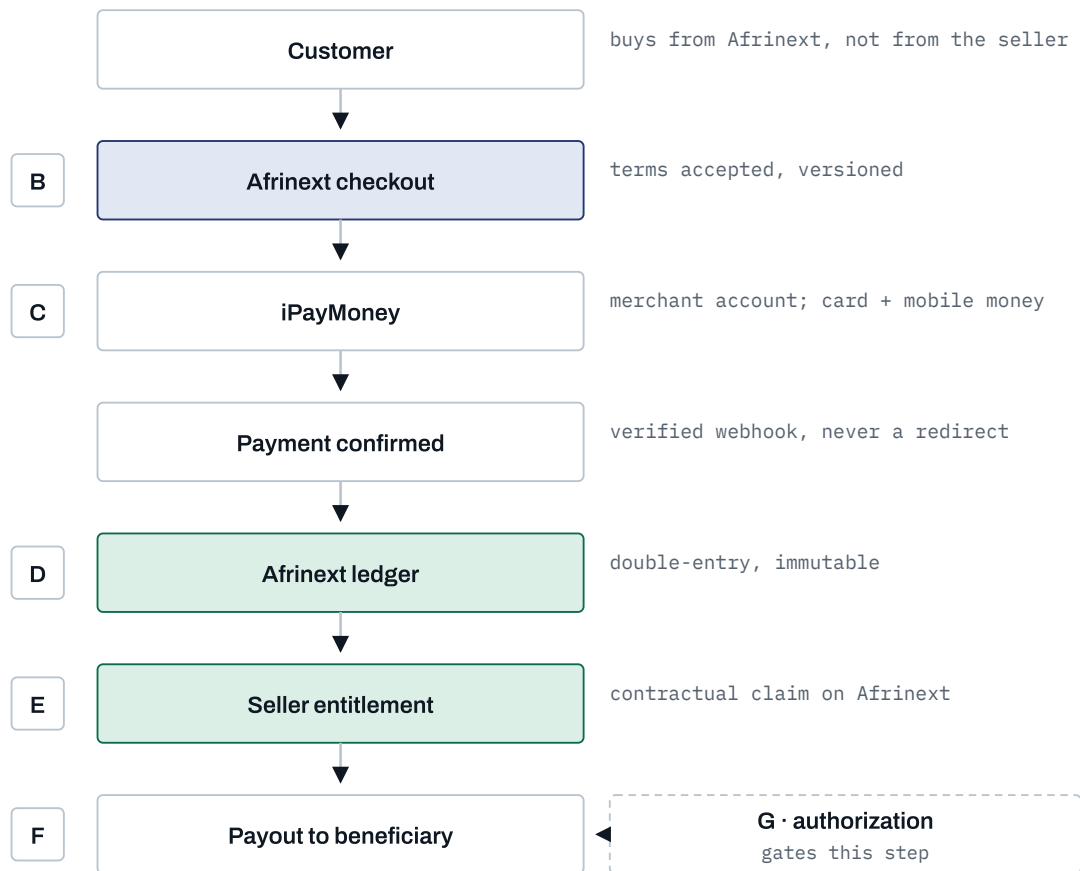
Afrinext is operated by **AFRI NEXT TECHNOLOGIE**, an *Entreprise Individuelle* registered in Niger, holding an NIF and an RCCM. Its registered activities include information technology, artificial intelligence, general commerce, service provision and import-export.

WHAT NIF AND RCCM ARE – AND ARE NOT

They establish that the business exists and is registered to trade: a tax identifier and a commercial-register entry. **They are not a payment-services or e-money licence.** Nothing in this document, in the product, in marketing copy, or in anything said to a user may describe them as one. Company registration and regulatory authorization are different things, granted by different authorities, for different activities.

The confirmed economic model

Afrinext operates as the **commercial platform of record**. The customer contracts with Afrinext, iPayMoney processes the payment, Afrinext's ledger records what each seller, instructor or partner is owed, and Afrinext pays the beneficiary under its own published terms and payout procedure. This is a confirmed business decision, and the architecture is built for it.



Each hop is governed by a different layer, and the layers are not interchangeable. The letters map to the table below. The one that is not yet settled — G — is the one that gates paying money out, which is why the payout rail is behind an interface rather than wired to a single provider.

Seven layers that must never be conflated

	LAYER	ESTABLISHED BY	DOES <i>NOT</i> ESTABLISH
A	Company registration AFRI NEXT TECHNOLOGIE exists and may trade	NIF, RCCM	Any right to conduct regulated payment activity
B	Contract with users Terms binding Afrinext and each user	Versioned acceptance records	Regulatory authorization
C	Payment-provider relationship Ability to accept card and mobile-money payments	iPayMoney merchant account	That Afrinext may itself hold or transmit funds as its own business activity
D	Afrinext internal ledger Authoritative record of who is owed what	Double-entry entries in Afrinext's database	Any claim on funds physically held anywhere
E	Seller economic entitlement A seller's claim against Afrinext	Ledger balance + accepted Seller Terms	A deposit, a bank balance, or protected client money
F	Payout operation The act of paying a beneficiary	Payout workflow + a provider or bank rail	Its own lawfulness — see G
G	Regulatory authorization Permission to conduct regulated payment activity	A licence, an exemption, or operating under a licensed institution	Nothing else in this table establishes it.

Afrinext intends to investigate and obtain whatever additional authorization its financial activities require. Until that is settled, three architectural consequences hold, and they are not negotiable in the code:

1. **The ledger models entitlement, not custody.** A seller's available balance is a contractual claim on Afrinext, and the schema, the API and the interface language all say so. No screen calls it a deposit, an account balance, or protected funds.
2. **The payout rail is an interface, not a provider.** Whatever posture G resolves to — Afrinext licensed, Afrinext operating under a licensed institution, or payouts executed by a third party — the change lands in one adapter, not across the codebase.
3. **Custody is an assumption, not a fact in the code.** Nothing in the ledger asserts where money physically sits. That is deliberate: if the answer changes, the accounting does not.

Consent: versioned, per document, per user

Users accept Afrinext's terms before using the commercial functionality those terms govern. Acceptance is recorded per document *version*, so the question

"which terms was this user bound by when they sold that course in March?"
has an answer.

```
CREATE TABLE legal_documents (  
  id          uuid PRIMARY KEY,  
  kind        text NOT NULL,      -- terms_of_use | privacy_policy | seller_terms |  
                                   -- instructor_terms | payment_refund_policy |  
                                   -- payout_terms | referral_terms | delivery_terms  
  country_code char(2),          -- NULL = applies everywhere  
  UNIQUE (kind, country_code)  
);  
  
CREATE TABLE legal_document_versions (  
  id          uuid PRIMARY KEY,  
  document_id uuid NOT NULL REFERENCES legal_documents(id),  
  version     text NOT NULL,      -- '2026-08-01' or semver; ordered by effective_from  
  locale      text NOT NULL,      -- fr | en  
  content_hash text NOT NULL,      -- sha256 of the exact text shown to the user  
  effective_from timestamptz NOT NULL,  
  UNIQUE (document_id, version, locale)  
);  
  
CREATE TABLE consent_records (  
  id          uuid PRIMARY KEY,  
  user_id     uuid NOT NULL REFERENCES users(id),  
  document_version_id uuid NOT NULL REFERENCES legal_document_versions(id),  
  accepted_at timestamptz NOT NULL DEFAULT now(),  
  ip_address  inet,  
  user_agent  text,  
  locale      text,  
  method      text NOT NULL,      -- signup_checkbox | seller_onboarding | reaccept ...  
  UNIQUE (user_id, document_version_id)  
);
```

Enforcement is a gate, not a banner: an action whose terms the user has not accepted at the *current effective version* is refused server-side, and the client is told which document to present. Publishing a new version therefore re-prompts affected users automatically, with the old acceptance preserved rather than overwritten — consent records are append-only, like ledger entries, for the same reason.

THE LINE THAT MUST NOT BE CROSSED

Consent establishes layer B. It does not establish layer G. A user agreeing to Afrinext's Payout Terms does not authorize Afrinext to conduct a regulated activity, and no amount of well-drafted terms substitutes for the competent authority's permission. Anyone who proposes otherwise has misread this section.



Technology stack

Every choice below is stated with the alternative I rejected, because several of them are genuine trade-offs rather than obvious calls.

LAYER	CHOICE	WHY THIS, OVER THE ALTERNATIVE
Language	TypeScript 5, strict	One language across web, worker and shared domain code. <code>strict</code> , <code>noUncheckedIndexedAccess</code> and <code>exactOptionalPropertyTypes</code> on from day one – retrofitting them into a 40-table codebase is miserable.
Web	Next.js 16, App Router	A marketplace lives or dies on organic search, so product, store and course pages need server rendering and stable URLs. React Server Components also ship less JavaScript to the low-end Android devices that dominate the target market. Rejected: a SPA + separate API, which doubles the deployment surface and loses SEO.
Domain logic	packages/core	Framework-free TypeScript. Next.js is transport, not the application. This is the single most important structural decision in the document – see section L.
Database	PostgreSQL 16+	Not negotiable. Real transactions, <code>SERIALIZABLE</code> isolation, CHECK and EXCLUSION constraints, deferred constraint triggers, partial indexes, <code>NUMERIC</code> , row-level locking, full-text search. The financial invariants belong in the database, not only in application code.
ORM	Drizzle ORM	See the decision block below – this one is contested.
Background jobs	pg-boss (Postgres-backed)	Lets a job be enqueued <i>inside the same transaction</i> as the ledger rows that job refers to. With Redis you get a two-phase failure: the database commits, the enqueue fails, and settlement silently never runs. Rejected: BullMQ + Redis, which is faster but buys throughput we do not have yet with a correctness hole we cannot afford. Revisit above roughly 100 jobs/second.
Auth	Better Auth + DB sessions	Phone-first OTP is a first-class requirement in this market, not an add-on. Database-backed sessions rather than stateless JWTs, because a session that controls a wallet must be revocable instantly. Rejected: Clerk and Auth0 (per-MAU USD pricing against XOF revenue), Lucia (retired upstream).
Validation	Zod	One schema per boundary – HTTP body, server action input, job payload, webhook payload – with types inferred rather than restated.
i18n	next-intl	French as the default locale, English second, locale in the URL path (<code>/fr/...</code>) so both index separately. Message catalogs live in <code>packages/i18n</code> so the worker can localise SMS and email too.
Styling	Tailwind v4 + tokens	Already in the repository, already token-driven, already dark-mode aware. No reason to change it.
Object storage	Cloudflare R2	Zero egress fees. For a platform whose core product is video in a market where bandwidth is the dominant cost, this is the difference between viable and not. S3-compatible, so the provider interface stays portable.
Video	Cloudflare Stream	Signed playback tokens, HLS adaptive bitrate, per-video access control. We store a <code>playback_id</code> , never a file URL. Alternatives worth pricing: Bunny Stream (cheaper), Mux (best tooling, most expensive). Rejected: MP4 files in a bucket – no adaptive bitrate on a 3G connection, and no way to expire access.
SMS / email	provider interface	SMS matters more than email here (OTP, order status, payout confirmations). Concrete provider chosen per country at deploy time; the interface is ours.
Observability	OpenTelemetry + Sentry	Structured logs carrying request id, actor id and ledger transaction id. A money platform without traceable financial events is not operable.

LAYER	CHOICE	WHY THIS, OVER THE ALTERNATIVE
Testing	Vitest + Playwright	Property-based unit tests on the ledger and commission engine; Playwright end-to-end on the purchase-to-payout path specifically.
Hosting	containers, Postgres in eu-west-3	Paris, not Cape Town: round-trip latency from Niamey, Bamako, Abidjan and Dakar to eu-west-3 is materially better than to af-south-1 . Cloudflare in front for edge caching. Vercel works for phases 0–2 but the worker is a long-running process that does not fit its model, so plan for containers.

CONTESTED DECISION

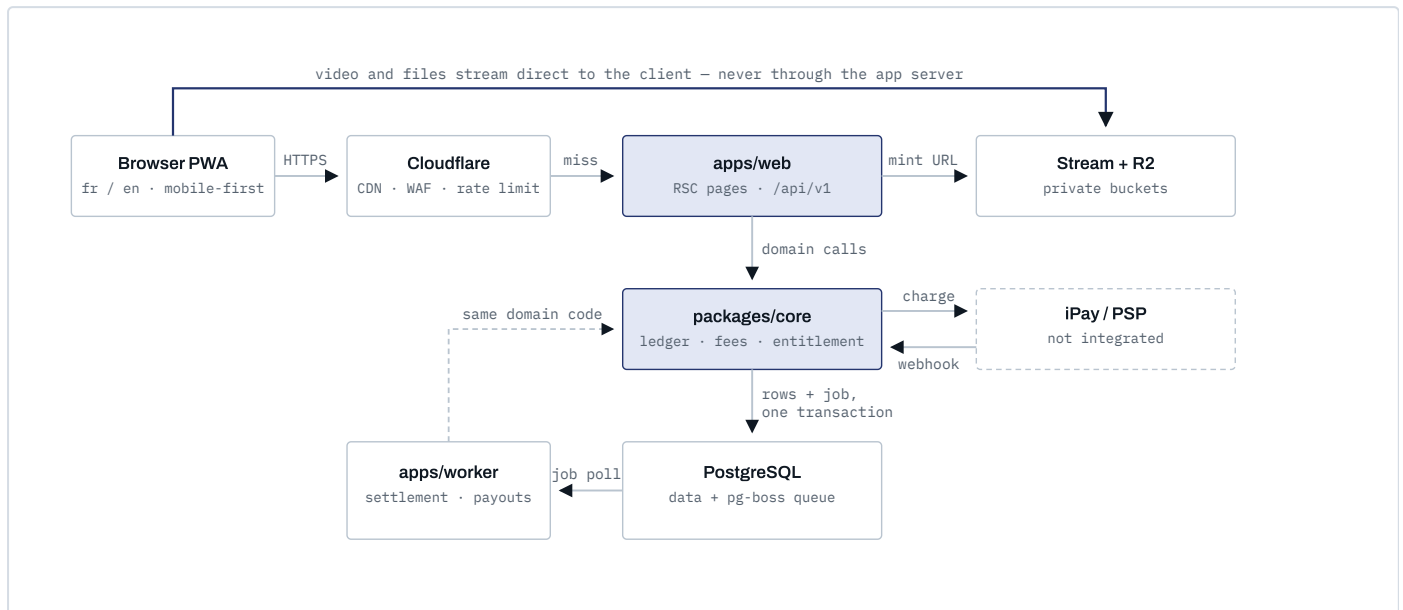
Drizzle ORM rather than Prisma

WHY	Migrations are plain SQL that a human reviews before it touches money. CHECK constraints, deferred constraint triggers and SELECT ... FOR UPDATE are expressible directly in the schema rather than through escape hatches. No query-engine binary, which matters for cold starts and for self-hosting cheaply.
INSTEAD OF	Prisma, which has better developer experience, better relational query ergonomics and far more mature migration tooling for a 40-table schema.
TRADE-OFF	More SQL written by hand, a smaller ecosystem, and a steeper ramp for developers who have only used Prisma.
SWITCH IF	The team is junior-weighted or Prisma-experienced. In that case take Prisma and write the ledger's critical paths as raw SQL — the schema in section C is unchanged either way. Tell me the team composition and I will pick.

System architecture

Four rules define the shape of the system. Everything else follows from them.

1. **Only `packages/core` touches the database.** Route handlers, server actions and job consumers all call the same domain services. There is no second path to the ledger.
2. **Jobs are enqueued in the transaction that creates their subject.** A settlement job and the ledger rows it will settle commit together or not at all.
3. **Media never passes through the application server.** The server mints a short-lived signed URL; the client fetches from storage directly.
4. **Webhooks are never processed inline.** Verify the signature, persist the raw event, return 200, and let the worker do the work. Payment providers retry aggressively and time out fast.



The database is the queue. Because pg-boss stores jobs in Postgres, a settlement job is inserted in the same transaction as the ledger entries it will later act on — the failure mode where money is recorded but its follow-up work is lost cannot occur. The dashed line from the worker means it imports `packages/core` rather than calling the web app.

Environments

Three: local (Docker Compose — Postgres, MinIO standing in for R2, a mock PSP), staging (real PSP sandbox, real Stream, anonymised data), production. Migrations run forward-only in CI with a tested rollback for each. Staging

must be able to run a full purchase-to-payout cycle before any production release touches the ledger.

Conventions that apply everywhere: UUIDv7 primary keys (time-sortable, so they index well and leak no sequence count); `timestampz` in UTC only; status enums rather than soft deletes except where retention law requires otherwise; and **money is never a bare number** — `amount_minor bigint` always travels with a `currency char(3)`.

AFRICA-SPECIFIC CORRECTNESS TRAP

XOF and XAF have **zero** decimal places. NGN (kobo) and GHS (pesewa) have two. Any code that assumes "minor units means cents, divide by 100" will be wrong by a factor of 100 across the entire UEMOA zone. The exponent comes from the `currencies` table, never from a constant.

The financial core

This is the part I would write first and change least. The rest of the schema can evolve; this cannot.

```

-- Money is always a pair, and the exponent is data, not a constant.
CREATE TABLE currencies (
  code      char(3) PRIMARY KEY,          -- XOF, XAF, NGN, GHS
  minor_unit smallint NOT NULL CHECK (minor_unit BETWEEN 0 AND 4),
  is_active  boolean NOT NULL DEFAULT true
);

CREATE TYPE ledger_account_kind AS ENUM (
  'user_available', -- withdrawable
  'user_pending',   -- earned, not yet releasable
  'platform_escrow', -- captured, owed to somebody, not yet split
  'platform_revenue',
  'psp_clearing',    -- money at the payment provider
  'payout_payable'   -- approved withdrawal, not yet paid out
);

CREATE TABLE ledger_accounts (
  id          uuid PRIMARY KEY,
  kind        ledger_account_kind NOT NULL,
  owner_type  text,                -- 'user' | 'store' | NULL for platform
  owner_id    uuid,
  currency    char(3) NOT NULL REFERENCES currencies(code),
  UNIQUE (kind, owner_type, owner_id, currency)
);

CREATE TABLE ledger_transactions (
  id          uuid PRIMARY KEY,          -- uuidv7
  kind        text NOT NULL,            -- capture | settlement | refund | payout ...
  occurred_at timestamptz NOT NULL DEFAULT now(),
  idempotency_key text UNIQUE,
  reverses_id uuid REFERENCES ledger_transactions(id),
  metadata    jsonb NOT NULL DEFAULT '{}' -- order_id, payment_id, actor...
);

CREATE TABLE ledger_entries (
  id          uuid PRIMARY KEY,
  transaction_id uuid NOT NULL REFERENCES ledger_transactions(id),
  account_id  uuid NOT NULL REFERENCES ledger_accounts(id),
  direction   smallint NOT NULL CHECK (direction IN (-1, 1)),
  amount_minor bigint NOT NULL CHECK (amount_minor > 0),
  currency    char(3) NOT NULL REFERENCES currencies(code)
);

-- Append-only. The application role cannot rewrite history.
REVOKE UPDATE, DELETE ON ledger_entries, ledger_transactions FROM afrinext_app;

-- Every transaction balances, per currency. Deferred, so all entries
-- can be inserted before the invariant is checked at COMMIT.
CREATE CONSTRAINT TRIGGER ledger_must_balance
  AFTER INSERT ON ledger_entries
  DEFERRABLE INITIALLY DEFERRED
  FOR EACH ROW EXECUTE FUNCTION assert_transaction_balanced();

-- A cache, never the truth. Rebuilt and asserted nightly.
CREATE TABLE account_balances (
  account_id  uuid PRIMARY KEY REFERENCES ledger_accounts(id),
  balance_minor bigint NOT NULL DEFAULT 0,
  entry_count bigint NOT NULL DEFAULT 0,
  updated_at  timestamptz NOT NULL DEFAULT now()
);

```

Entities by module

The brief listed candidate tables and asked me not to create them blindly. This is the filtered set, with the ones I would *not* build in phase 1 marked.

MODULE	TABLES	NOTES
Identity	users, user_identities, sessions, profiles, roles, permissions, role_permissions, role_assignments, countries, currencies, locales	<code>user_identities</code> holds one row per credential (phone, email, future OAuth) so a user can add a second login method without a schema change. <code>role_assignments</code> is scoped — see section D.
Stores	stores, store_settings, store_payout_accounts, <code>STORE_MEMBERS</code>	The <i>store</i> is the seller, not the user — orders reference <code>store_id</code> . <code>store_members</code> is deferred until multi-person stores are actually requested.
Catalog	categories, products, product_media, digital_assets, <code>PRODUCT_VARIANTS</code> , <code>INVENTORY_ITEMS</code> , <code>SERVICE_OFFERINGS</code>	One <code>products</code> table with a <code>kind</code> discriminator plus kind-specific side tables. Variants and inventory arrive with physical goods; service offerings with the services module.
Learn	courses, course_modules, course_lessons, lesson_assets, course_enrollments, lesson_progress, <code>COURSE_CERTIFICATES</code>	Certificates are a future feature in the brief and stay that way — but <code>enrollments</code> carries the completion data a certificate would need.
Commerce	carts, cart_items, checkout_groups, orders, order_items, order_fee_lines, order_events	<code>order_fee_lines</code> is the frozen commission snapshot — the reason changing a commission rate never rewrites history.
Payments	payment_intents, payment_attempts, payment_events, refunds	<code>payment_events</code> stores the raw provider payload with a <code>UNIQUE (provider, provider_event_id)</code> — this single constraint is what makes webhook replay harmless.
Ledger	ledger_accounts, ledger_transactions, ledger_entries, account_balances, settlement_holds, commission_rules, idempotency_keys	Above.
Payouts	withdrawal_requests, payout_batches, kyc_records	KYC tiers gate withdrawal ceilings. See section K.
Delivery	delivery_partners, delivery_orders, delivery_events, delivery_proofs, <code>CASH_COLLECTIONS</code>	Deferred to the physical-goods phase. <code>cash_collections</code> models the rider's cash float — see section I.
Referral	referral_programs, referral_codes, referral_attributions, referral_commissions	No <code>referral_relationships</code> tree — single level only, see section H.
Trust & ops	reviews, notifications, audit_logs, platform_settings, feature_flags, <code>DISPUTES</code> , <code>DISPUTE_MESSAGES</code>	Disputes arrive with physical goods, where they actually occur. Digital refunds in phase 1 are an admin action against an audited reversal.

Tables from the brief I would **not** create: `referral_relationships` (implied by single-level attribution), `user_roles` (superseded by scoped

`role_assignments`), and a separate `services` table (services are `products` with `kind = 'service'`).

Authentication

- **Phone + OTP is the primary method**, email + password secondary. Phone penetration far exceeds email use in the target countries, and phone is already the identifier for mobile money.
- **Database sessions, not JWTs.** An opaque token in an `httpOnly; Secure; SameSite=Lax` cookie, resolved against `sessions` on each request. A JWT cannot be revoked before it expires; a session that can move money must be killable in one query.
- Session rotation on privilege change, sign-in and password change. Shorter idle timeout for admin sessions than for shoppers.
- **Step-up re-verification** for money-sensitive actions: requesting a withdrawal, adding or changing a payout account, changing the phone number.

Authorization

Roles are scoped, additive rows. A single user simultaneously being a buyer, an instructor, a rider in Niamey and staff on someone else's store is the normal case, not an edge case.

```
CREATE TABLE role_assignments (
  id          uuid PRIMARY KEY,
  user_id     uuid NOT NULL REFERENCES users(id),
  role_id     uuid NOT NULL REFERENCES roles(id),
  scope_type  text NOT NULL,    -- 'global' | 'store' | 'course' | 'zone'
  scope_id    uuid,            -- NULL when scope_type = 'global'
  granted_by  uuid REFERENCES users(id),
  granted_at  timestampz NOT NULL DEFAULT now(),
  UNIQUE (user_id, role_id, scope_type, scope_id)
);
```

Permissions are strings of the form `resource.action` — `product.publish`, `order.refund`, `withdrawal.approve`, `lesson.view`. Roles hold sets of them. Every check goes through one function:

```
// packages/core/authz — the only permission gate in the system.
await authorize(actor, 'product.publish', { type: 'store', id: storeId });
```

RULE

IDOR is prevented by **scoping the query**, not by fetching a row and then checking it. Repository methods take the actor and constrain in SQL: a seller's order list is `WHERE store_id = ANY(actor.storeIds)` , never `findById()` followed by an ownership test. The second pattern works until someone forgets it once.

ADMINISTRATIVE ROLES ARE SPLIT BY LEAST PRIVILEGE

ROLE	CAN	CANNOT
support	Read users, orders, enrollments; resend receipts; open disputes	Touch the ledger, approve payouts, change commission rules
ops	Moderate catalog, verify stores, manage categories and delivery zones	Anything financial
finance	Approve withdrawals, issue refunds, post adjustments, view the ledger	Edit catalog, change permissions, alter user identities
superadmin	Role and settings administration	Approve their own withdrawal — a hard, code-level self-approval block

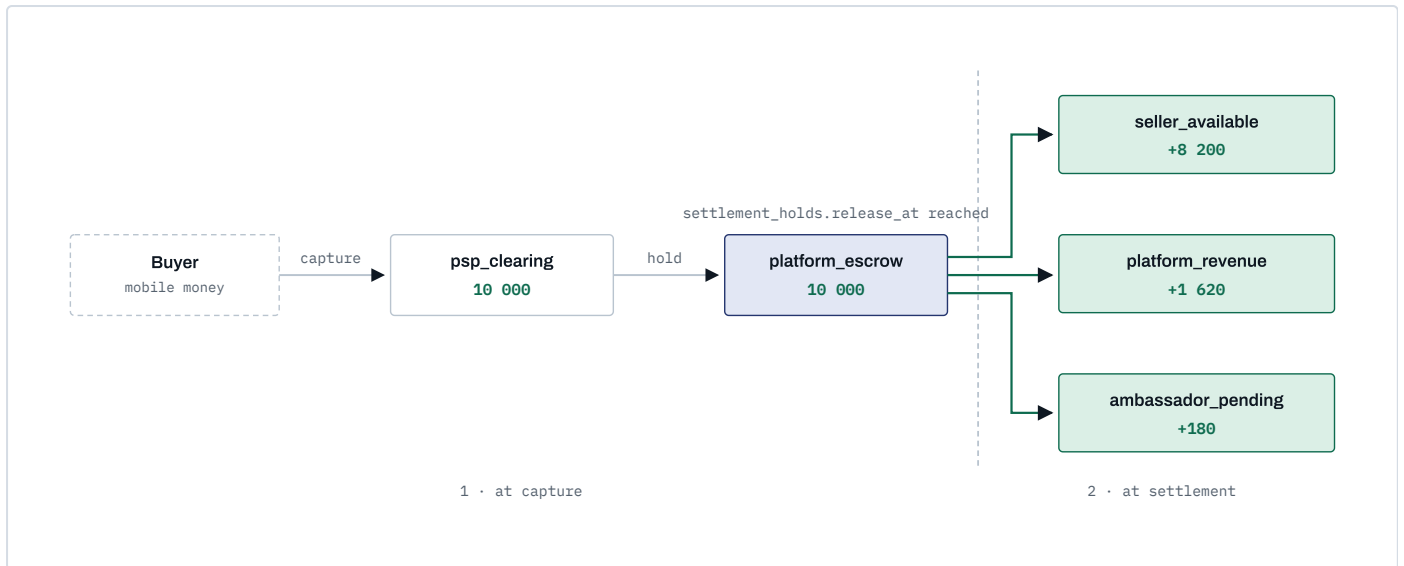
The wallet is not a balance field with rules around it. It is a **double-entry ledger**, and the balance is a derived quantity that we cache for speed and verify continuously.

The four invariants

1. **Entries are immutable.** No UPDATE, no DELETE — enforced by revoked grants, not by convention. A mistake is corrected by posting a compensating transaction linked through `reverses_id`.
2. **Every transaction balances.** Per transaction, per currency, the signed sum of entries is zero. A deferred constraint trigger rejects the COMMIT otherwise. Money cannot be created or destroyed by application code.
3. **Balances are cached, not authoritative.** `account_balances` is updated inside the same transaction under a row lock; a nightly job recomputes `SUM(direction × amount_minor)` per account and alarms on any drift.
4. **No floating point, anywhere.** `bigint` minor units and a currency code, from the database through the API to the rendered price.

Pending versus available

These are not statuses on a row. They are **two different accounts**, and "funds becoming withdrawable" is a transfer between them. That means the question "why is my money still pending?" is answerable by pointing at a specific ledger transaction and its `settlement_holds` row, rather than by reading application logic.



One 10 000 XOF course sale, at an 18% platform commission with a 10% referral program. Every arrow is one balanced ledger transaction. Note where the referral is drawn from: 180 is 10% of the *platform's* 1 800, not of the gross — so referral cost can never exceed what the platform earned on that sale. The ambassador's share lands in `pending` and is released separately once the buyer's refund window closes. For physical goods the seller's share also lands in `seller_pending` and moves to `available` on a second transaction when the delivery hold expires.

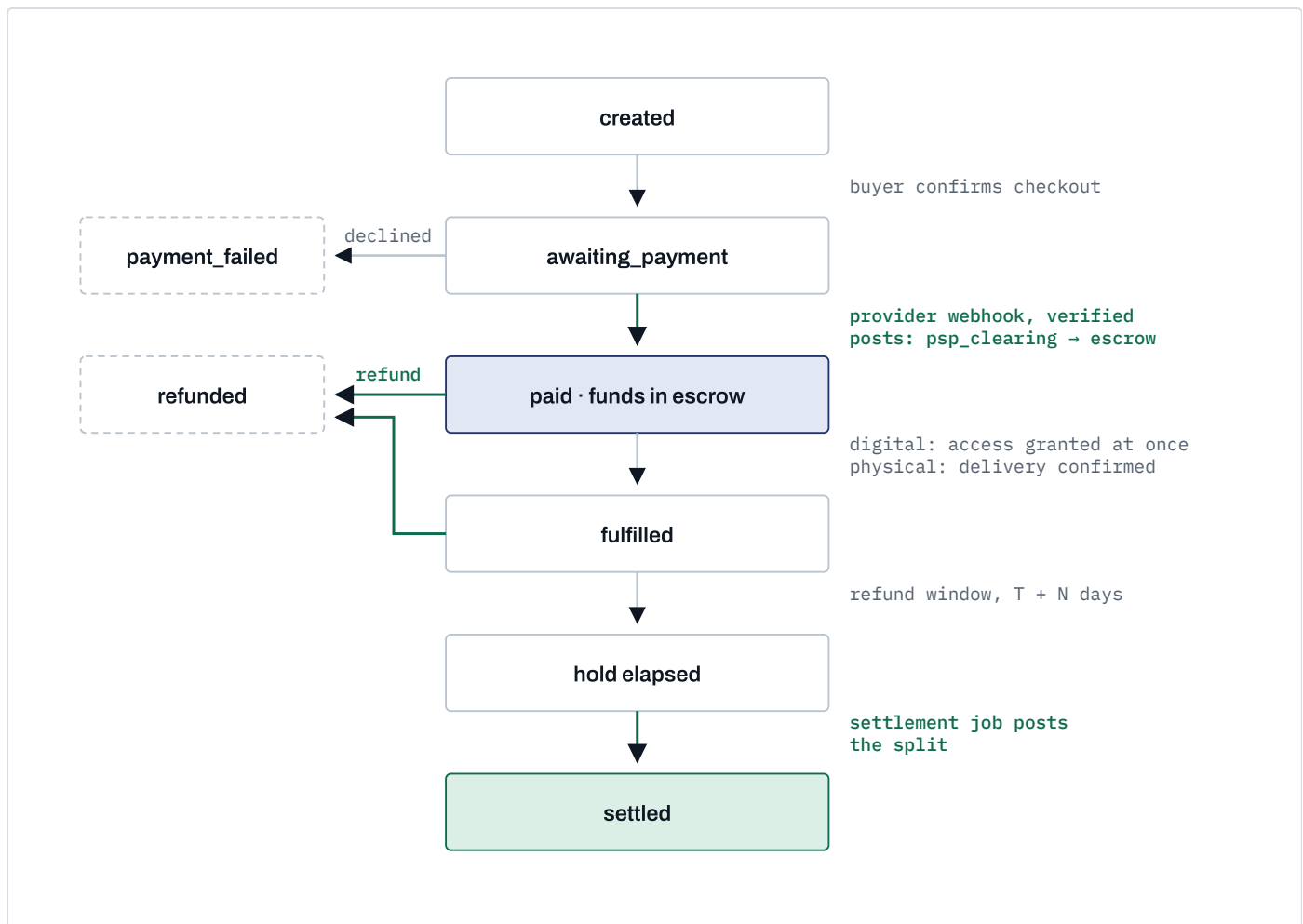
Rounding: the residual rule

Commission percentages rarely divide cleanly into whole francs. The rule is fixed and applied everywhere:

1. Compute every non-seller line (platform, referral, delivery) in minor units, rounding **half up**.
2. The seller's line is `gross - Σ(all other lines)`, never computed independently.

The split therefore re-sums to the gross by construction. No minor unit is ever created or lost to rounding, and the residual consistently favours the seller — a defensible position if it is ever questioned.

When money moves



Green transitions post ledger entries; grey ones only change order state.

Money enters escrow when the provider webhook is verified — never when the buyer returns from a redirect. A dispute does not get its own state: it *extends* the hold by pushing `settlement_holds.release_at` forward, so disputed money simply never reaches `available` while the dispute is open.

The commission engine

Rules are data. Resolution happens once, at order creation, and the result is frozen.

```
CREATE TABLE commission_rules (
  id          uuid PRIMARY KEY,
  transaction_type text NOT NULL, -- digital | course | physical | service | delivery | referral
  country_code char(2),          -- NULL = any
  category_id  uuid,             -- NULL = any
  store_id     uuid,             -- NULL = any; a negotiated rate for one seller
  rate_bps     integer,          -- basis points; 1800 = 18.00%
  fixed_minor  bigint,
  currency     char(3) REFERENCES currencies(code),
  priority     integer NOT NULL,
  effective_from timestampz NOT NULL,
  effective_to  timestampz
);
```

Resolution is most-specific-wins, broken by `priority` and then by `effective_from` — deterministic, and unit-testable in isolation. The resolved outcome is written to `order_fee_lines` with the `rule_id`, the basis and the computed amount.

WHY THE SNAPSHOT MATTERS

Raise the platform commission from 18% to 20% next quarter and **no historical order changes**. Every past settlement can still be re-derived from its own fee lines, and any seller asking "why did I receive this amount?" gets an answer that references the rule that was live at the moment they sold. A system that recomputes fees from current rules cannot answer that question truthfully.

Withdrawals

1. Request → validated against KYC tier ceiling, minimum amount, available balance, payout-account cooling period, and absence of open disputes.
2. Approved (automatically under a configured threshold, by `finance` above it) → ledger posts `user_available` → `payout_payable`. The money leaves the withdrawable balance at approval, so it cannot be double-spent while the payout is in flight.
3. Payout executed through the provider → on confirmation, `payout_payable` → `psp_clearing`.
4. On failure, a compensating transaction returns the amount to `user_available` and the request is marked failed with the provider's reason.

One products table, three kinds

`products.kind ∈ {physical, digital, service}`, with kind-specific side tables (`product_variants` + `inventory_items`, `digital_assets`, `service_offerings`). Not three separate tables — because carts, order items, reviews, search, favourites and fee resolution all need a single polymorphic target, and a three-table design forces a nullable triple foreign key into `order_items` that every query then has to unpack.

What differs between kinds is **fulfilment and hold policy**, and that lives in one place:

KIND	FULFILLED WHEN	DEFAULT HOLD
digital	Payment verified	24 h
course	Enrollment created	72 h
service	Buyer confirms, or auto after N days	7 d
physical	Delivery confirmed with proof	7 d

These are defaults in `platform_settings`, overridable per country and per category from the admin console — not constants in code.

Stores are the seller

Orders reference `store_id`, never `user_id`. This costs nothing now and buys three things later: a user can run more than one store; a store can gain staff without reshaping the order history; and a store can be transferred or suspended without touching the person's account, wallet or other roles.

Multi-store carts

A buyer will put a course from Dakar and a bag of shea butter from Bamako in one cart. At checkout the cart splits into **one order per store**, grouped under a `checkout_group_id`, paid by a single payment intent. Each order then settles independently on its own timeline — the course in 72 hours, the shea butter when it is delivered. Attempting to keep them as one order forces every fulfilment and refund decision to be all-or-nothing.

Search

Postgres full-text search with a generated `tsvector` column, plus `pg_trgm` for typo tolerance, and a French text-search configuration alongside English. Facets come from ordinary indexed columns. Move to Meilisearch or Typesense when the catalog passes roughly 100 000 rows or when faceted search gets heavy — not before, and not to Elasticsearch, which is an operational burden this team should not carry at launch.

Reviews

Only from a verified purchase: `reviews.order_item_id` is a required foreign key, unique per buyer per item. This kills fake-review farming structurally rather than through moderation, which matters when reviews feed seller ranking and seller ranking feeds income.

Structure is conventional — `courses` → `course_modules` → `course_lessons` → `lesson_assets`, with lesson kinds `video` | `pdf` | `text`. The interesting parts are entitlement and bandwidth.

Entitlement is checked at token-mint time, on every request

1. The player asks `GET /api/v1/learn/lessons/:id/playback`.
2. The server resolves the actor, checks `course_enrollments` for a live entitlement (and `access_expires_at` if the course is time-limited), and calls `authorize(actor, 'lesson.view', {course})`.
3. Only then does it mint a **signed Stream token, scoped to that user, valid 2–5 minutes**, and return an HLS manifest URL.
4. The player refreshes the token mid-playback as it nears expiry.
5. Every mint is written to `audit_logs` — which also gives instructors real "who watched what" analytics for free.

NEVER

Paid course content never has a permanent public URL. Not in a public bucket, not behind an unguessable path, not with a long-lived signed URL. An unguessable URL is a password that gets forwarded on WhatsApp.

Downloads are a per-asset instructor choice

`lesson_assets.downloadable boolean`, set by the instructor per asset. When true, downloading issues a separate short-TTL signed URL, logged, and rate-limited per user. When false, no download URL is ever minted — the flag is enforced server-side at mint time, not by hiding a button.

What is realistic about protection

BE HONEST WITH INSTRUCTORS

Signed short-lived URLs plus a burned-in overlay carrying the viewer's phone number make casual re-sharing traceable and inconvenient. They do **not** prevent a determined screen recording. Genuine prevention requires Widevine/FairPlay DRM, which is expensive and out of scope here. Instructors should be told this plainly rather than sold an assurance the platform cannot honour.

Progress and resume

`lesson_progress(enrollment_id, lesson_id, position_seconds, furthest_seconds, completed_at)` , written by a heartbeat every ~15 seconds, throttled, and flushed on pause and on unload via `sendBeacon` .

`course_enrollments.last_lesson_id` gives cross-device resume: the learner picks up on their phone exactly where they stopped on a shared laptop.

Keeping `furthest_seconds` separate from `position_seconds` means scrubbing backwards does not destroy completion state.

Built for the actual network

- An encoding ladder that **starts at 240p**, not at 720p. Adaptive bitrate matters far more here than peak quality.
- An audio-only rendition for lecture-style courses, selectable by the learner to save data.
- Progress writes are a few dozen bytes and batched — a learner should never lose their place because the heartbeat could not get through.
- Where the instructor permits downloads, offline viewing is the difference between a finished course and an abandoned one.

The brief's principle — pay for real economic activity, never for recruitment — is enforced structurally here, not by policy text.

Attribution

- An ambassador gets a code; the link is `/r/:code`, which sets a first-party cookie (90 days) and redirects.
- At signup the cookie is consumed into `referral_attributions(referrer_user_id, referred_user_id, program_id, attributed_at, expires_at)`, with `UNIQUE(referred_user_id)`.
- **First touch, immutable.** The first ambassador to introduce someone keeps the attribution. Last-touch invites a scramble to overwrite each other's referrals just before a purchase.

Qualification

A commission is created only when a **settled ledger transaction** of a configured type exists — not at signup, not on profile completion, not on "becoming active". There is no code path that pays for a registration, because commissions are computed by a job that reads settled transactions and has no other input.

CONFIGURABLE PER PROGRAM	EXAMPLE
Basis	platform_revenue
Rate	1000 bps (10%)
Duration from attribution	365 days
Per-referral lifetime cap	150 000 XOF
Eligible transaction types	course, digital, physical, service
Country scope	NE, ML, BF ...

CONFIRMED DECISION

Single level only — no downline of a downline

WHY	Confirmed by the business: A earns from B's qualifying activity; A never earns from B → C. Multi-level structures are where recruitment-scheme regulatory attention concentrates, and they contradict Afrinext's own stated principle. One level keeps the model explainable to a regulator in one sentence: "we share part of our commission with whoever introduced the seller."
INSTEAD OF	Two or more tiers, which measurably increases ambassador enthusiasm and measurably increases legal exposure.
TRADE-OFF	Slower ambassador-network growth than a tiered scheme would produce.
NOTE	Because the commission basis is platform revenue, the payout is bounded by definition — the platform can never owe more in referral than it earned on the sale. That guardrail is what makes the program safe to run at all, and it disappears if the basis is ever changed to gross.

Fraud controls

- Self-referral detection across phone number, device fingerprint, payout account and payment instrument.
- Referral commissions land in `ambassador_pending` and release only after the underlying order clears its refund window — so a wash sale that is refunded never pays out.
- Velocity limits per ambassador, with automatic hold and review above configured thresholds.
- Circular attribution (A refers B refers A) rejected at write time.

Deferred to the physical-goods phase, but designed now because it constrains the order state machine.

STATE MACHINE

requested → offered → accepted → picked_up → in_transit → delivered , with failed and cancelled as terminal branches. Every transition writes a delivery_events row with actor, timestamp and GPS point — the audit trail is the record, the current status is a cached projection of it.

DISPATCH

Offers broadcast to eligible partners in the zone; first acceptance wins via a conditional update (UPDATE ... WHERE status = 'offered') so two riders can never both hold the same job. Unaccepted offers expire and re-broadcast with a widening radius.

PROOF OF DELIVERY

A short OTP shown in the buyer's app and entered by the rider, plus an optional photo and the GPS fix at completion. The OTP is what flips the order to fulfilled and starts the settlement hold — a rider cannot self-declare a delivery into existence.

RIDERS LOSE SIGNAL CONSTANTLY

The rider interface queues state transitions locally and replays them with idempotency keys when connectivity returns. A transition applied twice must be a no-op; a transition applied out of order must be rejected by the state machine, not silently accepted.

CASH ON DELIVERY IS A BIGGER PROBLEM THAN IT LOOKS

COD is the dominant payment method for physical goods across much of the region, and it inverts the money flow: the rider collects cash, so the platform is owed money by the rider rather than holding the buyer's funds. That needs a cash_collections liability account per rider, a deposit and reconciliation process, float limits, and a real operational routine — it is a project, not a checkbox. **My recommendation is to launch physical goods prepaid-only and add COD as its own phase with its own design.**

Two entry styles, one implementation. **Server Actions** for first-party form mutations (fewer round trips, progressive enhancement) and **versioned REST** at `/api/v1/*` for everything a future native app, an ambassador tool or a partner integration would consume. Both call the same `packages/core` services. Logic is never duplicated between them, and neither one is allowed a private path to the database.

DOMAIN	REPRESENTATIVE ENDPOINTS
auth	POST <code>/auth/otp/request</code> · <code>/auth/otp/verify</code> · <code>/auth/session</code> · DELETE <code>/auth/session</code>
me	GET <code>/me</code> · PATCH <code>/me</code> · GET <code>/me/roles</code> · GET <code>/me/orders</code> · GET <code>/me/enrollments</code>
stores	POST <code>/stores</code> · GET <code>/stores/:slug</code> · PATCH <code>/stores/:id</code> · GET <code>/stores/:id/analytics</code>
catalog	GET <code>/products</code> · GET <code>/products/:slug</code> · POST <code>/stores/:id/products</code> · POST <code>/products/:id/publish</code>
search	GET <code>/search?q&kind&category&country&cursor</code>
cart · checkout	GET/POST <code>/cart/items</code> · POST <code>/checkout</code> · GET <code>/checkout/:groupId</code>
orders	GET <code>/orders</code> · GET <code>/orders/:id</code> · POST <code>/orders/:id/cancel</code> · POST <code>/orders/:id/refund</code>
payments	POST <code>/payments/intents</code> · GET <code>/payments/:id</code> · POST <code>/webhooks/:provider</code>
wallet	GET <code>/wallet</code> · GET <code>/wallet/transactions</code> · POST <code>/wallet/withdrawals</code> · GET <code>/wallet/withdrawals/:id</code>
learn	GET <code>/courses/:slug</code> · GET <code>/learn/lessons/:id</code> · POST <code>/learn/lessons/:id/progress</code> · GET <code>/learn/lessons/:id/playback</code>
delivery	GET <code>/delivery/offers</code> · POST <code>/delivery/:id/accept</code> · POST <code>/delivery/:id/transition</code>
referrals	GET <code>/referrals/me</code> · GET <code>/referrals/commissions</code> · GET <code>/r/:code</code>
admin	<code>/admin/*</code> – mirrors the above under <code>admin.*</code> permissions

CONVENTIONS

- **Idempotency-Key** is required on every POST that moves money. The key, the request hash and the resulting transaction id are stored; a replay returns the original response rather than acting twice.
- Cursor pagination everywhere (`?cursor=&limit=`). Offset pagination on a growing catalog silently skips and duplicates rows.
- Responses are `{ data, meta }`; errors are `{ error: { code, message, fields } }` with **stable machine-readable codes** — clients must never branch on message text, which is localised.
- Money crosses the wire as `{ amountMinor: 8200, currency: "XOF" }`. Never a formatted string, never a float.
- Rate limits by route class: strictest on OTP send and verify, then auth, then write, then read.
- Webhooks return `200` as fast as possible after signature verification and persistence. All work happens in the worker.

CONTROL	WHERE IT IS ENFORCED
Authentication	Opaque session tokens in <code>httpOnly; Secure; SameSite=Lax</code> cookies, resolved server-side. Rotated on sign-in and privilege change. Argon2id for the password path.
Step-up verification	Fresh OTP required for withdrawal requests, payout-account changes and phone changes — regardless of session age.
Authorization	One <code>authorize()</code> choke point in <code>packages/core/authz</code> . No route handler makes its own decision.
IDOR	Prevented by scoping queries to the actor in SQL, not by post-fetch ownership checks.
Input validation	Zod at every boundary; database CHECK and FK constraints as the last line. Frontend validation is a convenience and is never trusted.
Rate limiting	Per IP and per user, at the edge and in the app. Hardest limits on OTP send/verify, login, withdrawal, and playback-token minting.
Webhook integrity	Signature verified against the raw body before parsing; timestamp freshness window; <code>UNIQUE (provider, provider_event_id)</code> makes replay a no-op.
File access	Private buckets only. Short-TTL signed URLs minted after an entitlement check. Every mint audited.
Payment card data	Never touched. Provider-hosted collection only, which keeps PCI scope at SAQ-A. This is a deliberate architectural constraint, not an oversight.
Audit	Append-only <code>audit_logs</code> for every admin action and every financial state change: actor, action, target, before/after, IP, user agent, request id.
Fraud	Velocity checks, device fingerprinting, a cooling period before first withdrawal to a newly added payout account, and automatic hold-and-review thresholds.
Separation of duty	No user can approve a withdrawal to an account they control. Enforced in code, not in policy.
Secrets	Environment only, distinct per environment, rotated. Sandbox and production provider credentials never coexist in one config.
Data protection	PII minimised and encrypted at rest; retention policy per data class; export and deletion paths built for Nigeria's NDPR, Ghana's Data Protection Act and UEMOA national regimes.

EXPLICITLY OUT OF SCOPE, AND NAMED AS SUCH

DRM for video (Widevine/FairPlay). A third-party penetration test — which should be scheduled and budgeted *before* public launch, not after. Formal PCI-DSS certification beyond SAQ-A. Automated AML transaction-monitoring beyond threshold rules.

pnpm workspaces plus Turborepo. The directory layout is not cosmetic — it is what physically prevents domain logic from leaking into the framework.

```

afrinext/
├─ apps/
│  ├─ web/           Next.js 16 – pages, route handlers, server actions
│  └─ worker/        long-running pg-boss consumers
├─ packages/
│  ├─ core/          framework-free domain logic – the application
│  │  ├─ money/      Money type, minor units, rounding, formatting
│  │  ├─ ledger/     posting, balances, reconciliation
│  │  ├─ commissions/ rule resolution, fee snapshots
│  │  ├─ orders/     order + settlement state machines
│  │  ├─ payments/   PaymentProvider interface + registry
│  │  ├─ learn/      entitlement, playback tokens, progress
│  │  ├─ delivery/
│  │  └─ referrals/
│  │     └─ authz/   permissions, authorize()
│  ├─ db/            Drizzle schema, SQL migrations, seeds
│  ├─ providers/     psp-ipay, psp-manual, storage-r2, video-stream, sms, email
│  ├─ ui/            design system (seeded from today's prototype)
│  ├─ i18n/          fr / en message catalogs, shared with the worker
│  └─ config/        tsconfig, eslint, tailwind preset
├─ docs/
│  └─ architecture/  this document
│  └─ adr/           architecture decision records, numbered
│  └─ runbooks/      reconciliation drift, stuck payout, failed webhook
└─ infra/           docker, compose, CI, deploy

```

THE RULE THAT MAKES THIS WORTH DOING

`packages/core` may import `packages/db`. It may **not** import anything from `next`, and this is enforced by an ESLint boundary rule in CI, not by discipline. The consequence: the ledger and commission engine are testable in milliseconds without a server, the worker runs identical business logic to the web app, and extracting a standalone API service later is a packaging change rather than a rewrite.

Development roadmap

Phases are ordered by *irreversibility*, not by visibility. The money spine comes before any product feature, because it is the thing that cannot be retrofitted. Durations assume two to three engineers and are estimates, not commitments.

PHASE	SCOPE	EXIT CRITERION – THE THING THAT MUST DEMONSTRABLY WORK	EST.
P0 Foundations	Monorepo, Postgres, Drizzle schema v1, auth (phone OTP + email), scoped RBAC, i18n, design system extraction, CI, observability skeleton	A user registers by phone, signs in, switches language. CI runs typecheck, lint, tests and migrations forward and back on every commit.	2 wk
P1 Money spine	money , ledger , commission engine, idempotency, settlement holds, reconciliation job, admin ledger viewer	Property-based tests over 10 000 randomised operations prove every transaction balances and the cached balance equals the sum of entries. An injected drift is caught by the reconciliation job. No product feature is built before this passes.	3 wk
P2 Stores & catalog	Store creation, digital products and courses as products, categories, media upload to R2, public storefront and product pages, search	A seller publishes a paid digital product that renders server-side at a public URL with correct metadata and appears in search.	3 wk
P3 Cycle closed, no PSP	Cart, checkout, orders, fee snapshots, and a ManualTransferProvider where an admin confirms receipt	The complete economic cycle runs end to end without any payment integration: buyer orders → admin confirms → ledger settles → seller sees earnings → requests withdrawal → finance marks it paid. This de-risks everything that depends on iPay.	3 wk
P4 iPay	Real provider implementation behind the existing interface	In sandbox: charge created, webhook signature verified, status query reconciled, refund executed, replay proven harmless. GATED Cannot start until the documentation and sandbox credentials in section P are in hand.	unknown
P5 Afrinext Learn	Modules, lessons, Stream upload, entitlement, signed playback, progress and resume, download flag, learner interface	An automated test proves a paid lesson is unplayable without entitlement, and that resume works across two devices for one learner.	4 wk
P6 Wallet & payouts	Wallet interface, KYC tiers, withdrawal flow with step-up auth, payout batches, finance console	Full withdrawal lifecycle including a provider failure that correctly reverses back to available balance.	3 wk
P7 Network	Referral programs, attribution, qualification, commissions, ambassador dashboard, fraud checks	Tests prove a commission can only originate from a settled transaction, that self-referral is blocked, and that a refunded order pays nothing.	3 wk
P8 Physical & delivery	Variants, inventory, shipping, delivery partner interface, state machine, proof of delivery, delivery earnings	A physical order settles only on OTP-confirmed delivery, and a rider replaying a queued transition twice changes nothing.	5 wk
P9 Services & creators	Service offerings, booking and request flow, creator categories and portfolios	A service settles on buyer confirmation, and on auto-confirmation after the configured window.	3 wk
P10 Hardening	Load test, penetration test, runbooks, restore drill, compliance review, admin settings completeness	A database restore is performed from backup against a stopwatch, and the recovery time is written down.	3 wk

The admin console is **not** a phase. Each phase ships the admin surface for what it built; an admin console deferred to the end is an admin console that never gets finished.

To the recommended launch vertical (P0–P3, P5, P6, plus P4 whenever iPay unblocks): roughly **18 weeks**. Full scope as briefed: roughly **32 weeks**. If iPay stalls, P3's manual rail means you can onboard real sellers and take real money by bank transfer while it is resolved.

RISK 1 – THE ONE THAT CAN STOP THE PROJECT

Afrinext receiving customer money and paying sellers may be a regulated activity. The operator, AFRI NEXT TECHNOLOGIE, is a registered *Entreprise Individuelle* with an NIF and RCCM — which establishes layer A in section 01, and nothing beyond it. In the UEMOA zone, taking money from a buyer, holding a seller's entitlement and disbursing it can fall under BCEAO e-money and payment-services rules. Afrinext intends to investigate and obtain whatever authorization is required. Until that resolves, the architecture reduces exposure the only way engineering can: the ledger records *entitlement* rather than asserting custody, and the payout rail sits behind an interface so the answer can change without a rewrite. **This gates P6 (payouts), not P0 or P1.**

RISK	SEV	MITIGATION
Ledger correctness — a bug here is money, and it is discovered by users	HIGH	Double-entry with database-enforced balancing, immutability by revoked grants, property-based tests, nightly reconciliation with alarms, ledger built in P1 before anything depends on it
iPay is an unknown — the API may lack payouts or refunds entirely	HIGH	Provider abstraction plus the manual rail in P3, so no other phase is blocked. Section P lists exactly what is needed to remove this risk
Referral fraud and scheme perception	MED	Single level, commission drawn from platform revenue only, qualification from settled transactions only, pending-until-refund-window, self-referral detection
Scope — the brief is a 32-week product and enthusiasm compounds	HIGH	The launch vertical in section 00; phases with hard exit criteria; nothing starts until the prior phase's criterion demonstrably passes
KYC and AML on withdrawals	MED	Tiered KYC with withdrawal ceilings per tier; identity verification before the first payout; threshold-based holds. Provider choice still open
Mobile money reversal semantics differ from cards and vary by operator	MED	Conservative hold windows, configurable per country and per provider; never assume card-like chargeback behaviour
Video bandwidth cost and learner data cost	MED	R2 zero-egress, ladder starting at 240p, audio-only rendition, permitted offline download
Latency from West Africa	LOW	Postgres in <code>eu-west-3</code> , Cloudflare edge caching. Measure real round-trip from Niamey, Lagos and Accra in P0 and revisit if the numbers disagree with the assumption
Cash on delivery reconciliation	MED	Recommend launching physical goods prepaid-only; COD gets its own phase and its own liability model
Cross-jurisdiction data protection	MED	PII minimisation, encryption at rest, per-class retention, export and deletion paths built in P0 rather than bolted on
Operating a money system on-call	MED	Runbooks written in the phase that creates the failure mode; reconciliation alarms route to a human; restore drill rehearsed in P10

P

iPayMoney: confirmed provider, unverified API

iPayMoney is the confirmed initial payment provider, and Afrinext already holds a merchant account. That settles the commercial question. It does not settle the engineering one.

VERIFICATION STATUS – READ BEFORE TRUSTING ANYTHING BELOW

The official iPayMoney documentation is **not present in this repository**, and the provider's domain is **not reachable from the build environment** – outbound egress to it is blocked by the network policy. I have therefore verified *nothing* about their API: not the authentication scheme, not an endpoint, not a payload, not a webhook signature, not a status value.

The capabilities reported to me – Mobile Money, credit cards, local and international cards, a JavaScript SDK and an Android SDK – are recorded here as **stated by the business, pending confirmation from the official documentation**. No code treats them as facts.

ITEM	STATE
<code>PaymentProvider</code> interface	BUILT Provider-agnostic; nothing in it assumes iPayMoney.
<code>MockPaymentProvider</code>	BUILT Deterministic, in-process, for development and tests. Refuses to load when <code>NODE_ENV=production</code> .
<code>iPayMoneyProvider</code> adapter	BOUNDARY ONLY The adapter and its registration exist; every method throws <code>ProviderNotConfiguredError</code> naming the missing documentation. It cannot silently appear to work.
Real endpoints, auth, payloads, webhook verification	NOT IMPLEMENTED Blocked on the list below.
Integration test structure	PREPARED Specs exist and skip unless sandbox credentials are present in the environment.

The abstraction Afrinext codes against. `createPayout` is optional deliberately – if iPayMoney has no disbursement API, payouts run as an operational batch and the platform still works, but the finance team's workload changes substantially, so it is worth establishing early.

```
interface PaymentProvider {
  readonly id: string;
  createCharge(input: ChargeInput): Promise<ChargeResult>;
  getCharge(providerRef: string): Promise<ChargeStatus>;
  verifyWebhook(rawBody: Buffer, headers: HeadersLike): Promise<VerifiedEvent>;
  refund(input: RefundInput): Promise<RefundResult>;
  createPayout?(input: PayoutInput): Promise<PayoutResult>; // may not exist
  getPayout?(providerRef: string): Promise<PayoutStatus>;
}
```

Exactly what is needed to unblock the adapter

Items 6, 7 and 8 are the ones that most often invalidate an assumed design, so they matter most.

#	REQUIRED FROM THE OFFICIAL DOCUMENTATION	WHY IT BLOCKS
1	Base URLs, sandbox and production	Nothing can be called without them
2	Authentication scheme (API key, HMAC, OAuth) and where credentials go in a request	Determines secret storage and rotation
3	Charge initiation request/response schema, and supported channels per country	Determines the checkout data model
4	Flow type: hosted redirect, inline widget, JS SDK, or USSD push	Changes the checkout interface, not just the backend
5	Status query endpoint and the <i>complete</i> status enumeration	Reconciliation cannot be written against a partial enum
6	Webhooks: registration, payload schema, signature algorithm and header name, timestamp tolerance, retry policy	Money enters the ledger on a verified webhook; with no signature scheme there is no safe way to accept one
7	Currency handling — specifically whether XOF is sent as whole francs	XOF has zero decimal places; a wrong assumption is a 100× error
8	Whether a payout/disbursement API exists, and its settlement timing	Decides whether payouts are automated or operational
9	Refund API and its constraints (partial refunds, time limits)	The refund reversal path in the ledger
10	Idempotency support on charge creation, and rate limits	Retry safety
11	Settlement schedule to the merchant account (T+N) and fee structure	Hold windows and platform margin
12	Sandbox credentials and test numbers or accounts per channel	Nothing can be tested without them
13	JavaScript and Android SDK documentation, if the SDK route is used	Changes the client integration entirely

Drop the documentation into `docs/providers/ipaymoney/` in any form — PDF, exported HTML, an OpenAPI file, a Postman collection. Once it is there the

adapter is implementable against verified facts instead of assumptions.

Anything unimplemented, unverified or assumed is listed here rather than left to inference. Current as of revision 2 of this document.

ITEM	STATUS
Sections A–M of this blueprint	ARCHITECTURE Design, not code. Phase 0 implements the foundation only; the rest is not built.
iPayMoney integration	NOT IMPLEMENTED Merchant account exists; the API is unverified and unreachable from the build environment. Interface and mock exist; the adapter throws. See section P.
Regulatory authorization (layer G)	UNRESOLVED Company registration (NIF, RCCM) establishes layer A only. Requires local counsel and, if needed, an application to the competent authority. Gates P6.
Legal document texts (Terms, Privacy, Seller, Instructor, Payout, Referral)	NOT WRITTEN The consent <i>architecture</i> exists; the documents themselves are a legal deliverable, not an engineering one.
Cloudflare Stream / R2, SMS provider, KYC provider	NOT SELECTED Recommended, not procured. No accounts, no confirmed pricing.
Latency assumption (<code>eu-west-3</code> over <code>af-south-1</code>)	UNVERIFIED Based on general routing, not measurement from Niamey. Verify in P0 or P1.
Effort estimates in section M	ESTIMATES Two to three engineers assumed. Not commitments.
ORM choice (Drizzle vs Prisma)	PROCEEDING ON THE RECOMMENDATION Phase 0 uses Drizzle. The decision genuinely depends on team composition, which is still unanswered — see section Q.
V2 (physical, delivery) and V3 (creator, services) architecture	DESIGNED, NOT BUILT Retained deliberately.



Decisions: settled, and still open

Settled — reflected throughout this document

DECISION	OUTCOME
Operating company	AFRI NEXT TECHNOLOGIE, <i>Entreprise Individuelle</i> , Niger, NIF + RCCM. Registration is layer A and nothing more — section 01.
Economic model	Afrinext is the commercial platform of record: it receives customer payments and pays beneficiaries under its own terms.
Launch scope	V1 = digital products and courses. V2 physical + delivery, V3 creator + services, both designed and deferred.
Launch market	Niger, XOF — as data, not as constants.
Payment provider	iPayMoney, merchant account held. Behind the provider interface; a second provider must remain possible.
Referral	Single level. Basis is Afrinext's realized commission, never gross. No payment for registration or recruitment.
Ledger	Double-entry design approved in principle. Not to be replaced by a balance field.
Consent	Versioned acceptance per document, per user. Establishes contract, not authorization.

Still open

None of these block Phase 0. Items 1 and 2 block later phases and are worth starting now because they have long lead times.

#	QUESTION	BLOCKS
1	Regulatory. Who is advising on layer G, and what authorization is Afrinext pursuing — its own licence, or operating under a licensed institution?	P6 payouts. Long lead time — start now.
2	iPayMoney documentation. The 13 items in section P. Sandbox credentials are the single most useful thing you can send.	P4 payment integration
3	Team composition. How many engineers, and what is their Prisma versus raw-SQL experience?	Settles the ORM choice; Phase 0 proceeds on Drizzle meanwhile
4	Hosting. Managed (Vercel + Neon, higher unit cost) or containers (Hetzner or Fly, cheaper, more operations)?	P0 deployment, not P0 code
5	SMS provider for OTP in Niger. Which aggregator, and what are the per-message economics?	Real OTP delivery. The OTP architecture is provider-agnostic, so this is not urgent.
6	Native app. Is the PWA sufficient at launch, or is store distribution required?	How much weight the REST layer carries
7	KYC. Which identity documents are practically verifiable in Niger, and is there an existing provider?	P6 withdrawal tiers
8	Legal document texts. Who drafts the Terms, Seller Terms, Payout Terms and the rest?	Nothing technical — the consent machinery works with any text

Phase 0 is authorised and in progress: the monorepo, the schema, authentication, scoped permissions, the consent tables, the audit log, the ledger with its property tests, and the payment-provider abstraction. Phase 1 does not begin without an explicit approval.